

Nexan CatQuest Online

모의해킹 결과 보고서

항목	내용
대상 기업	Nexan
대상 서비스	CatQuest Online 게임 웹 서비스
진단 유형	시나리오 기반 모의해킹 / 웹 애플리케이션 보안 진단 / 내부망 침투 시뮬레이션
진단 대상	웹 서버, DNS 서버, 게임 DB, 개인정보 DB, 로그 서버, 관리자 페이지, 보안관제 시스템
작성자	김보미
진단 기간	2026 년 06 월 10 일 ~ 2026 년 06 월 15 일
작성일	2026 년 06 월 16 일
문서 성격	모의해킹 결과 보고서

목차

- 1. 표지
- 2. 문서 개요
- 3. 진단 대상 환경
- 4. 진단 범위
- 5. 진단 방법론
- 6. 전체 공격 시나리오
- 7. 주요 취약점 요약
- 8. 주요 취약점 상세 분석
- 9. 취약점별 탐지 및 로그 증적 요약
- 10. 종합 위험도 평가
- 11. 보안 권고안
- 12. 최종 결론

2. 문서 개요

2.1 프로젝트 목적

본 프로젝트는 가상의 게임회사 Nexan 의 게임 웹 서비스인 CatQuest Online 을 대상으로 실무 환경과 유사한 모의해킹을 수행하고, 그 결과를 보고서 형태로 정리하는 것을 목적으로 한다. CatQuest Online 은 회원가입, 로그인, 스테이지 진행, 상점 구매, 쿠폰 사용, 친구 메시지, 관리자 페이지, 공지사항, 파일 업로드, 게임 DB, 개인정보 DB 등을 포함하는 웹 기반 게임 서비스이다.

본 진단에서는 개별 취약점의 존재 여부뿐 아니라, 외부 공격자가 인터넷 구간에서 DMZ 웹 서버를 공격하고 이후 내부망 서버 및 데이터베이스로 접근을 확장할 수 있는지 확인한다. 또한 공격 과정에서 발생한 로그가 Wazuh, GoAccess, Zabbix, PMM 등 보안관제 및 모니터링 시스템에서 탐지 가능한지 함께 점검한다.

2.2 보고서 작성 목적

본 보고서는 CatQuest Online 서비스에서 발견된 보안 취약점과 그 영향도를 정리하고, 공격 재현 절차, 증적 자료, 위험도 평가, 대응 방안, 이행점검 결과를 제시하기 위해 작성되었다. 각 취약점은 공격 흐름과 방어자 관점의 탐지 근거를 함께 확인할 수 있도록 구성하였다.



반드시 보이게 할 항목			
공격 대상 기능명	변조 값	결과 값	로그 시각
상점 구매	price 1000 → 1	1 Gold로 구매 성공	2026-06-18 14:22:10

🎯 **증거 목적:** 보고서에서 사진이 어떤 방식으로 쓰이는지 설명

📋 **설명:** 공격 전 화면, Burp 요청, DB 확인, GoAccess/Wazuh 탐지 화면을 하나의 흐름으로 구성한 예시

그림 0-1 보고서 증거 구성 예시

3. 진단 대상 환경

3.1 전체 네트워크 토폴로지

Nexan Games의 네트워크는 외부망, DMZ, 사내 내부망, 내부 서버망으로 구성되어 있다. 외부 공격자는 인터넷 구간의 Kali 공격자 시스템을 통해 DMZ에 위치한 WEB 서버와 DNS 서버를 대상으로 공격을 수행한다. DMZ 서버는 내부망과 방화벽을 통해 분리되어 있으며, 내부 서버망에는 게임 DB, 개인정보 DB, 로그 DB, Wazuh 서버, Zabbix/GoAccess/PMW 서버, SFTP 서버가 위치한다.

다만, 실습 환경의 제약으로 인해 실제 외부 인터넷 구간에서 공격을 수행하는 것은 제한적이므로, 본 진단에서는 내부망 내 Kali 공격자 시스템을 활용하여 외부 공격 상황을 모의하는 방식으로 진행한다. 또한 실습 환경 특성상 서버 실행 주체, 가상머신 구동 상태, 네트워크 장애 여부에 따라 접속 IP가 일부 변경될 수 있다. 이에 따라 시연 캡처 화면에 표시된 URL 또는 IP가 서로 다르게 보일 수 있으나, 해당 증거는 모두 동일한 CatQuest 실습 환경에서 수행된 결과이다. 본 진단에서 기본적으로 사용하는 통합 접속 IP는 아래에 별도로 명시한다.

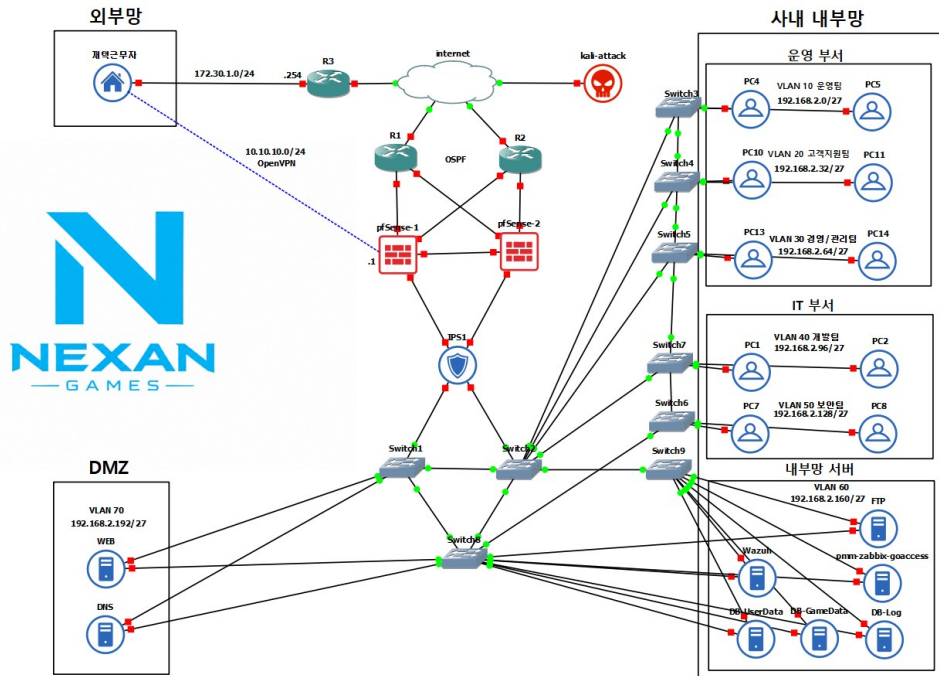


그림 1 Nexan Games 전체 네트워크 토폴로지

3.2 네트워크 구성 요약

구분	대역	주요 구성
외부망	172.30.1.0/24	재택근무자, 외부 접속 구간
OpenVPN	10.10.10.0/24	원격 접속 구간
DMZ	VLAN 70 / 192.168.2.192/27	WEB 서버, DNS 서버
운영팀	VLAN 10 / 192.168.2.0/27	운영팀 PC
고객지원팀	VLAN 20 / 192.168.2.32/27	고객지원팀 PC
경영/관리팀	VLAN 30 / 192.168.2.64/27	관리팀 PC
개발팀	VLAN 40 / 192.168.2.96/27	개발팀 PC
보안팀	VLAN 50 / 192.168.2.128/27	보안팀 PC
내부 서버망	VLAN 60 / 192.168.2.160/27	SFTP, LOG, DB 서버

3.3 주요 서버 구성

서버명	위치	역할	주요 진단 포인트
WEB Server	DMZ	CatQuest 웹 서비스 제공	웹 취약점, 관리자 페이지, 파일 업로드, 세션 관리
DNS Server	DMZ	도메인 질의 응답	DNS 정보 노출, 존 전송 가능성, 설정 오류

서버명	위치	역할	주요 진단 포인트
DB-Game Server	내부 서버망	게임 데이터 저장	게임 재화, 아이템, 쿠폰, 스테이지 정보
DB-PI Server	내부 서버망	개인정보 저장	개인정보 접근 통제, DB 계정 권한
DB-Log Server	내부 서버망	로그 저장	로그 저장, 위변조 가능성
Wazuh Server	내부 서버망	보안 이벤트 탐지	공격 로그 탐지, 에이전트 상태
PMM/Zabbix/GoAccess Server	내부 서버망	DB/서버/웹 로그 모니터링	접근 로그 분석, 장애 및 성능 모니터링
SFTP 서버	내부 서버망	파일 전송 및 백업	계정 관리, 파일 노출, 내부 이동 가능성

4. 진단 범위

4.1 포함 범위

구분	진단 항목	설명	관련 증적
외부 공격	인터넷 구간에서 DMZ 대상 공격	Kali 공격자 시스템에서 WEB, DNS 등 공개 구간 대상 공격 수행	그림 2 외부 공격자 관점 포트 스캔 결과 그림 3 서비스 배너 확인 결과 그림 4 gobuster 디렉터리 탐색 결과 그림 5 DNS 질의 결과
웹 애플리케이션	CatQuest Online 기능 진단	로그인, 스테이지, 상점, 쿠폰, 친구 메시지, 공지사항 등	그림 V-01-1~V-01-3 스테이지 API 요청 조작 증적 그림 V-02-1~V-02-2 상점 가격 조작 증적 그림 V-03-1~V-03-5 쿠폰 중복 사용 증적 그림 V-04~V-07 각 취약점별 재현 증적
관리자 페이지	관리자 기능 접근 제어	일반 사용자 및 비로그인 사용자의 접근 가능 여부 확인	그림 V-05-1~V-05-6 공지사항 작성/수정 페이지 XSS 증적
DB 보안	게임 DB 및 개인정보 DB 접근 통제	웹 서버 침해 후 내부 DB 접근 가능성 확인	그림 B-1 purchase_history 구매 기록 확인 화면 그림 B-2 shop_items 정상 가격 확인 화면 그림 B-3 보유 골드 차감 결과 화면

구분	진단 항목	설명	관련 증적
내부망 이동	DMZ 에서 내부 서버망 접근 가능성	방화벽 정책 및 서버 간 접근 제어 확인	그림 5-1 WEB 서버 → SFTP 서버 접근 확인 그림 5-2 WEB 서버 → Wazuh 서버 접근 확인 그림 5-3 WEB 서버 → Zabbix/PMM/GoAccess 서버 접근 확인 그림 5-4~5-6 WEB 서버 → 내부 DB 서버 접근 확인
로그 및 관제	공격 탐지 여부	Wazuh, GoAccess, Zabbix, PMM 에서 공격 흔적 확인	그림 9-1 GoAccess 대시보드 전체 화면 그림 9-2 /api/shop/buy 요청 확인 화면 그림 9-3 /api/coupon/claim 요청 확인 화면 그림 9-4 Wazuh 대시보드 화면 그림 9-5 PMM DB 모니터링 화면

※ 위 표의 관련 증적은 표 안에 사진을 직접 삽입하는 의미가 아니라, 보고서 본문에 크게 배치할 캡처 화면의 그림 번호를 의미한다.

4.2 주의 사항

서비스 거부 공격은 시스템을 장시간 중단시키는 방식이 아니라 요청 제한, 오류 처리, 임계치 초과 탐지 여부를 확인하는 수준으로 제한한다. 개인정보 진단은 실제 개인정보가 아닌 실습용 더미 데이터를 대상으로 수행하며, 외부 반출은 수행하지 않는다.

5. 진단 방법론

5.1 외부 정보 수집

외부 공격자 관점에서 접근 가능한 IP, 도메인, 포트, 서비스 정보를 확인한다. 이 단계의 사진은 공격 표면이 어떻게 식별되었는지 보여주는 근거가 된다.

```

(red@kali-Attacker)-[~]
$ nmap -p- 192.168.2.193
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-16 03:24 -0400
Nmap scan report for 192.168.2.193
Host is up (0.0011s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
5000/tcp  open  upnp
8888/tcp  open  sun-answerbook

Nmap done: 1 IP address (1 host up) scanned in 6.40 seconds

```

그림 2 nmap 포트 스캔 결과

```

(red@kali-Attacker)-[~]
$ nmap -sC -sV -p- -A 192.168.2.193
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-16 03:27 -0400
Nmap scan report for 192.168.2.193
Host is up (0.00075s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2)
|_ ssh-hostkey:
|   256 14:c2:8a:59:d1:d7:7b:dd:98:96:15:d4:68:58:93:77 (ECDSA)
|_  256 90:72:6e:17:f3:26:bf:eb:fd:8d:fe:a7:2c:58:1d:fb (ED25519)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
|_ http-server-header: Apache/2.4.58 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
5000/tcp  open  http     Werkzeug httpd 3.1.8 (Python 3.12.3)
|_ http-server-header: Werkzeug/3.1.8 Python/3.12.3
|_ http-title: Nexan Games - \xEB\xA1\x9C\xEA\xB7\xB8\xEC\x9D\xB8
|_ Requested resource was /login
8888/tcp  open  http     Werkzeug httpd 3.1.8 (Python 3.12.3)
|_ http-server-header: Werkzeug/3.1.8 Python/3.12.3
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
|_ Requested resource was /login
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4
OS details: Linux 4.19 - 5.15
Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 993/tcp)
HOP RTT      ADDRESS
1   0.22 ms pfSense-1.home.arpa (192.168.1.1)
2   0.56 ms 192.168.10.1
3   0.65 ms 192.168.2.193

OS and Service detection performed. Please report any incorrect results at https://nmap.org
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.61 seconds

```

그림 3 서비스 배너 확인 결과


```

(red@kali-Attacker)-[~]
$ sudo gobuster dir -u http://192.168.2.193:5000 -w /usr/share/wordlists/dirbuster/directo
ry-list-lowercase-2.3-medium.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.2.193:5000
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-med
ium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
login (Status: 200) [Size: 2290]
register (Status: 200) [Size: 6762]
profile (Status: 302) [Size: 199] [--> /login]
shop (Status: 302) [Size: 199] [--> /login]
chat (Status: 302) [Size: 199] [--> /login]
tutorial (Status: 302) [Size: 199] [--> /login]
friends (Status: 302) [Size: 199] [--> /login]
logout (Status: 302) [Size: 199] [--> /login]
notices (Status: 302) [Size: 199] [--> /login]
coupons (Status: 302) [Size: 199] [--> /login]
console (Status: 400) [Size: 167]
mailbox (Status: 302) [Size: 199] [--> /login]
lobby (Status: 302) [Size: 199] [--> /login]
Progress: 207641 / 207641 (100.00%)
=====
Finished
=====

```

```

(red@kali-Attacker)-[~]
$ gobuster dir -u http://192.168.2.193:8888 -w /usr/share/wordlists/di
rbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.2.193:8888
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-li
st-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
login (Status: 200) [Size: 1160]
upgrade (Status: 302) [Size: 199] [--> /login]
logout (Status: 302) [Size: 199] [--> /login]
notice (Status: 302) [Size: 199] [--> /login]
console (Status: 400) [Size: 167]
verify (Status: 302) [Size: 199] [--> /login]
Progress: 220558 / 220558 (100.00%)
=====
Finished
=====

```

그림 4 gobuster 디렉터리 탐색 결과


```
C:\Users\ruddl>nslookup nexangames.com
서버:      Unknown
Address:    192.168.2.196

이름:      nexangames.com
Address:    192.168.2.193

C:\Users\ruddl>
```

그림 5 nslookup 결과

5.2 웹 애플리케이션 진단

기능	진단 내용	주요 증적
로그인/회원가입	인증 우회, 세션 관리, 개인정보 입력 검증	로그인 요청, 세션 쿠키, 실패 응답
스테이지	스테이지 API 요청 조작, stage 값 변조	/api/move 요청, stage 파라미터 변조, 접근 로그
상점	가격 조작, 아이템 중복 구매	상점 화면, price 변조
쿠폰	중복 사용, 보상 반복 수령	쿠폰 요청 반복, 보상 증가, 쿠폰 이력
전투	공격력/체력/스테이지 값 조작	attack 변조, 보스 처치, 보상 지급
친구 메시지	IDOR, 타 사용자 메시지 조회/삭제	message_id 변조, 타인 메시지 조회, 403 차단
공지사항/업로드	저장형 XSS, 파일 업로드 취약점	multipart 요청, 업로드 파일 접근, Wazuh FIM

5.3 내부망 침투 가능성 점검

DMZ의 WEB 서버가 침해되었다는 가정하에 WEB 서버에서 내부 서버망 주요 자산으로 ICMP 및 TCP 포트 연결이 가능한지 확인하였다. 아래 증적은 내부망 접근 가능 여부와 방화벽/서비스 포트 정책을 확인하기 위한 결과이다.

```

=====
[출발지 서버 확인]
HOSTNAME : nexan-web
IP       : 192.168.2.193
ZONE     : DMZ - WEB Server
=====

===== [TEST 1] WEB -> SFTP Server =====
SOURCE : WEB / 192.168.2.193
TARGET : SFTP / 192.168.2.161
PORT   : 22 / SFTP-SSH
PING 192.168.2.161 (192.168.2.161) 56(84) bytes of data.
64 bytes from 192.168.2.161: icmp_seq=1 ttl=63 time=0.225 ms
64 bytes from 192.168.2.161: icmp_seq=2 ttl=63 time=0.269 ms

--- 192.168.2.161 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1025ms
rtt min/avg/max/mdev = 0.225/0.247/0.269/0.022 ms
Connection to 192.168.2.161 22 port [tcp/ssh] succeeded!

```

그림 5-1 WEB 서버에서 SFTP 서버(22/TCP) 접근을 확인한 화면

```

===== [TEST 2] WEB -> Wazuh Server =====
SOURCE : WEB / 192.168.2.193
TARGET : Wazuh / 192.168.2.162
PORT   : 1514, 1515, 55000
PING 192.168.2.162 (192.168.2.162) 56(84) bytes of data.
64 bytes from 192.168.2.162: icmp_seq=1 ttl=63 time=0.325 ms
64 bytes from 192.168.2.162: icmp_seq=2 ttl=63 time=0.237 ms

--- 192.168.2.162 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1030ms
rtt min/avg/max/mdev = 0.237/0.281/0.325/0.044 ms
nc: connect to 192.168.2.162 port 1514 (tcp) failed: Connection refused
Connection to 192.168.2.162 1515 port [tcp/*] succeeded!
nc: connect to 192.168.2.162 port 55000 (tcp) failed: Connection refused

```

그림 5-2 WEB 서버에서 Wazuh 서버(1514/1515/55000 TCP) 접근을 확인한 화면

```
===== [TEST 3] WEB -> PMM-Zabbix-GoAccess Server =====
SOURCE : WEB / 192.168.2.193
TARGET : PMM-Zabbix-GoAccess / 192.168.2.163
PORT : 9443/Zabbix, 8443/PMM, 7443/GoAccess
PING 192.168.2.163 (192.168.2.163) 56(84) bytes of data.
64 bytes from 192.168.2.163: icmp_seq=1 ttl=63 time=0.219 ms
64 bytes from 192.168.2.163: icmp_seq=2 ttl=63 time=0.301 ms

--- 192.168.2.163 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1039ms
rtt min/avg/max/mdev = 0.219/0.260/0.301/0.041 ms
Connection to 192.168.2.163 9443 port [tcp/*] succeeded!
Connection to 192.168.2.163 8443 port [tcp/*] succeeded!
Connection to 192.168.2.163 7443 port [tcp/*] succeeded!
```

그림 5-3 WEB 서버에서 Zabbix/PMM/GoAccess 서버(9443/8443/7443 TCP) 접근을 확인한 화면

```
===== [TEST 4] WEB -> DB-UserData Server =====
SOURCE : WEB / 192.168.2.193
TARGET : DB-UserData / 192.168.2.164
PORT : 3306 / MySQL-MariaDB
PING 192.168.2.164 (192.168.2.164) 56(84) bytes of data.
64 bytes from 192.168.2.164: icmp_seq=1 ttl=63 time=0.225 ms
64 bytes from 192.168.2.164: icmp_seq=2 ttl=63 time=0.312 ms

--- 192.168.2.164 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1017ms
rtt min/avg/max/mdev = 0.225/0.268/0.312/0.043 ms
Connection to 192.168.2.164 3306 port [tcp/mysql] succeeded!
```

그림 5-4 WEB 서버에서 개인정보 DB 서버(3306/TCP) 접근을 확인한 화면

```
===== [TEST 5] WEB -> DB-GameData Server =====
SOURCE : WEB / 192.168.2.193
TARGET : DB-GameData / 192.168.2.165
PORT : 3306 / MySQL-MariaDB
PING 192.168.2.165 (192.168.2.165) 56(84) bytes of data.
64 bytes from 192.168.2.165: icmp_seq=1 ttl=63 time=0.262 ms
64 bytes from 192.168.2.165: icmp_seq=2 ttl=63 time=0.314 ms

--- 192.168.2.165 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1019ms
rtt min/avg/max/mdev = 0.262/0.288/0.314/0.026 ms
Connection to 192.168.2.165 3306 port [tcp/mysql] succeeded!
```

그림 5-5 WEB 서버에서 게임 DB 서버(3306/TCP) 접근을 확인한 화면

```

===== [TEST 6] WEB -> DB-Log Server =====
SOURCE : WEB / 192.168.2.193
TARGET : DB-Log / 192.168.2.166
PORT   : 3306 / MySQL-MariaDB
PING 192.168.2.166 (192.168.2.166) 56(84) bytes of data.
64 bytes from 192.168.2.166: icmp_seq=1 ttl=63 time=0.252 ms
64 bytes from 192.168.2.166: icmp_seq=2 ttl=63 time=0.267 ms

--- 192.168.2.166 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1019ms
rtt min/avg/max/mdev = 0.252/0.259/0.267/0.007 ms
Connection to 192.168.2.166 3306 port [tcp/mysql] succeeded!

```

그림 5-6 WEB 서버에서 로그 DB 서버(3306/TCP) 접근을 확인한 화면

5.4 로그 및 관제 점검

도구	점검 내용	사진에 포함할 항목
Wazuh	웹셀 업로드, 비정상 로그인, 파일 변경, 권한 상승 시도 탐지	이벤트명, 에이전트, 룰 ID, 심각도
GoAccess	비정상 URL 요청, 404/500 증가, 관리자 페이지 접근 시도 분석	요청 URL, 응답 코드, 요청 횟수
Zabbix	CPU, 메모리, 디스크, 서비스 상태 변화 확인	호스트명, 트리거, 그래프
PMM	DB 접속 증가, 비정상 쿼리, 성능 저하 확인	DB 인스턴스, 쿼리 수, 연결 수
DB-Log	사용자 행위 및 관리자 행위 로그 저장 여부 확인	user_id, action, created_at

6. 전체 공격 시나리오

6.1 시나리오 개요

공격자는 외부 인터넷 구간의 Kali 공격자 시스템에서 Nexan Games의 DMZ에 위치한 CatQuest WEB 서버와 DNS 서버를 대상으로 정보 수집을 수행한다. 이후 웹 서비스의 기능을 분석하여 상점 가격 조작, 스테이지 우회, 쿠폰 중복 사용, 친구 메시지 IDOR, 저장형 XSS, 파일 업로드 취약점 등을 확인한다.

공격자는 웹 애플리케이션 취약점을 이용하여 일반 사용자 권한에서 관리자 기능 접근 또는 웹 서버 권한 획득을 시도한다. 이후 DMZ 웹 서버에서 내부 서버망의 게임 DB, 개인정보 DB, 로그 DB로 접근 가능한지 확인하고, 방화벽 및 접근 제어 정책의 적절성을 평가한다. 방어자 관점에서는 해당 공격 행위가 Wazuh, GoAccess, Zabbix, PMM 및 DB-Log에 기록되고 탐지되는지 확인한다.

6.2 공격 흐름도

[그림 6] CatQuest Online 공격 시나리오 흐름도

nexangames.com 기준: 외부 정보수집 → 웹 취약점 악용 → 내부 DB 접근 가능성 확인 → 로그 및 보안관제 확인

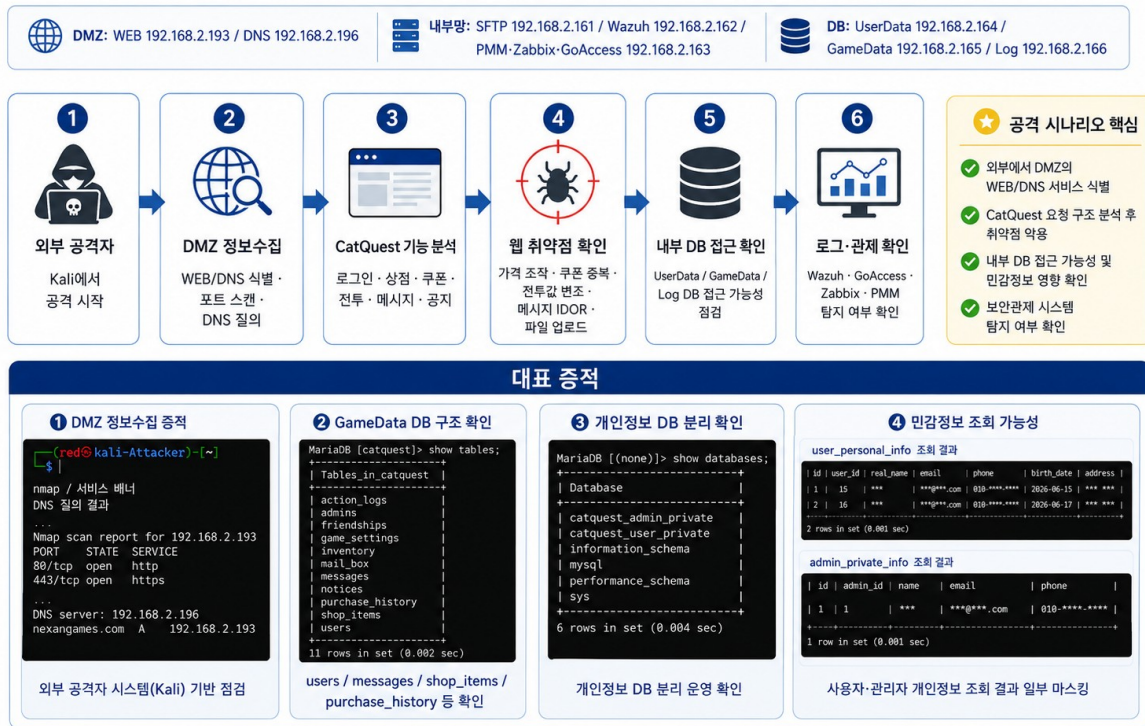


그림 6 공격 시나리오 흐름도

단계	공격자 행위	확인할 증적
1	외부에서 WEB/DNS 정보 수집	nmap, 서비스 배너, DNS 질의
2	CatQuest 주요 기능 분석	정상 화면, 요청 구조, 파라미터
3	상점/쿠폰/전투 요청값 변조	Burp Repeater, 서버 응답, 게임 결과
4	친구 메시지 IDOR 및 파일 업로드 확인	message_id 변조, 업로드 요청, 파일 접근
5	WEB 서버에서 내부 DB 접근 가능성 확인	DB 접속 시도, 방화벽 로그
6	보안관제 탐지 확인	GoAccess, Wazuh, Zabbix, PMM, DB-Log

7. 주요 취약점 요약

번호	취약점명	위험도	영향 대상	주요 영향	핵심 증적
V-01	스테이지 API 요청 조작	Medium	게임 스테이지 기능	이전 스테이지 클리어 조건 우회, 비정상적인 스테이지 진입	Burp /api/move 요청, stage 값 변조, 미해금 스테이지 접근 화면

번호	취약점명	위험도	영향 대상	주요 영향	핵심 증적
V-02	상점 가격 조작	High	상점 기능 / 게임 DB	비정상적인 저가 구매, 게임 재화 밸런스 훼손	price 변조 요청, 변조 후 구매 결과 화면
V-03	쿠폰 중복 사용	High	쿠폰 보상 로직 / 사용자 DB	골드/아이템 보상 중복 획득, 게임 경제 악용	쿠폰 화면, 반복 요청 후 성공 알림
V-04	Flask Debug Traceback 정보 노출	High	Flask 웹 애플리케이션	서버 경로·함수명·코드 라인 노출	오류 유발 요청, traceback 응답 화면
V-05	공지사항 작성 및 수정 페이지 XSS	High	관리자 공지 기능 / 사용자 브라우저	스크립트 실행, 세션 탈취 및 피싱 가능성	공지 입력값, alert 실행, 공지 상세 화면
V-06	친구 메시지 링크 미리보기 XSS 및 명령 실행 가능성	Critical	친구 메시지 / 링크 미리보기 서버	서버 측 요청 처리 악용, 내부 정보 노출 및 명령 실행 가능성	메시지 미리보기, 서버명 출력 결과
V-07	파일명 기반 OS Command Injection	Critical	공지 첨부파일 업로드 / 웹서버	웹서버 권한 명령 실행, 내부 침투 거점화 가능성	업로드 파일명, 파일 선택, 실행 결과 화면

8. 주요 취약점 상세 분석

본 절에서는 주요 취약점별 재현 과정과 공격 결과를 화면 및 로그 증적과 함께 정리한다.

V-01. 스테이지 API 요청 조작

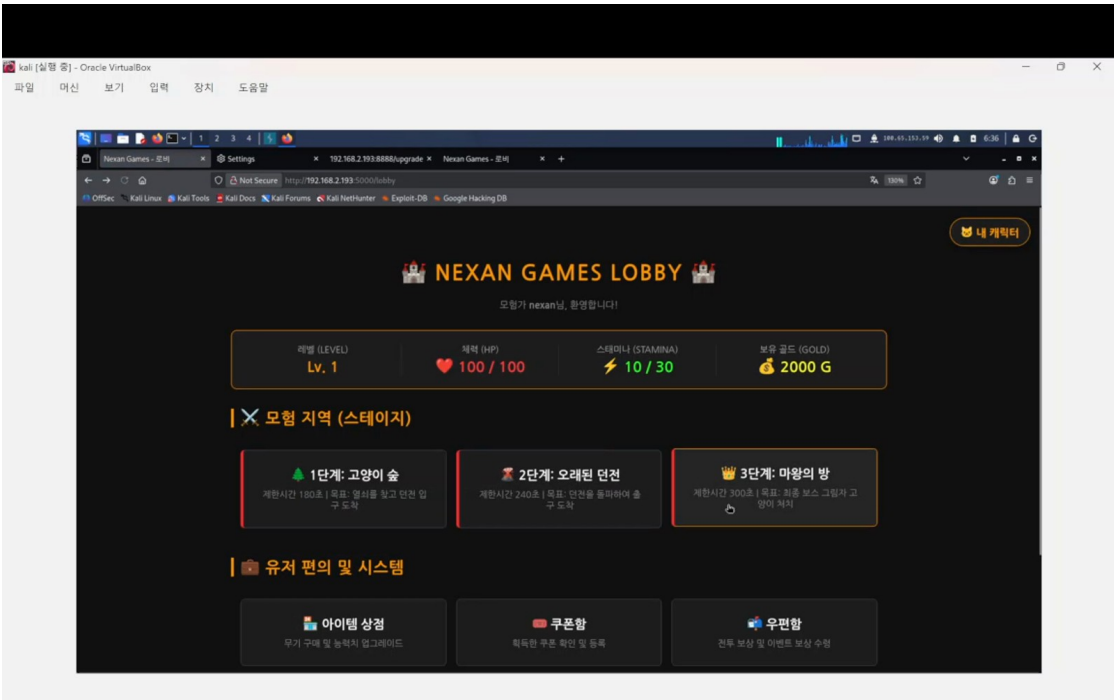
1) 취약점 개요

클라이언트가 전송하는 stage 값을 조작하여 미해금 스테이지에 접근할 수 있었다. /api/move 요청 처리 시 사용자의 실제 클리어 상태와 요청 stage 값에 대한 서버 측 검증이 부족하여 이전 스테이지 클리어 조건을 우회하고 비정상적인 스테이지 진입이 가능한 것으로 확인되었다.

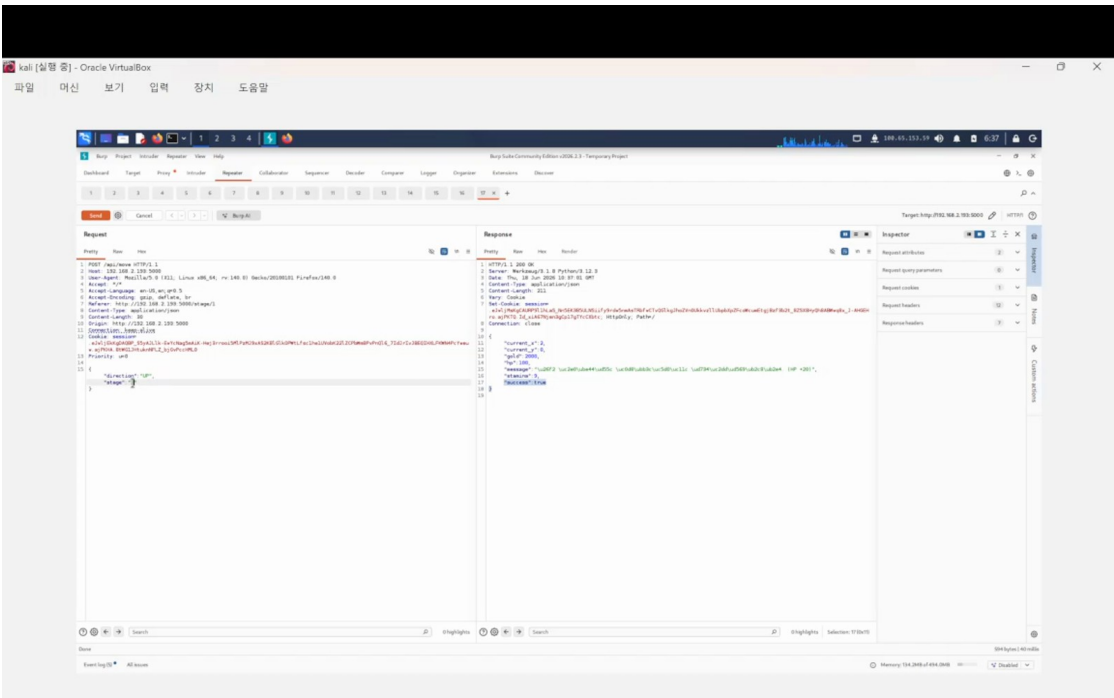
2) 취약점 정보

항목	내용
취약점 ID	V-01
취약점명	스테이지 API 요청 조작
위험도	Medium
영향 대상	CatQuest 스테이지 이동 API 및 진행 검증 기능
발생 위치	/api/move
요청 방식	POST
관련 파라미터	stage, direction
증적 출처	공격 시연 영상 모음 및 추가 친구 XSS 시연 영상 캡처

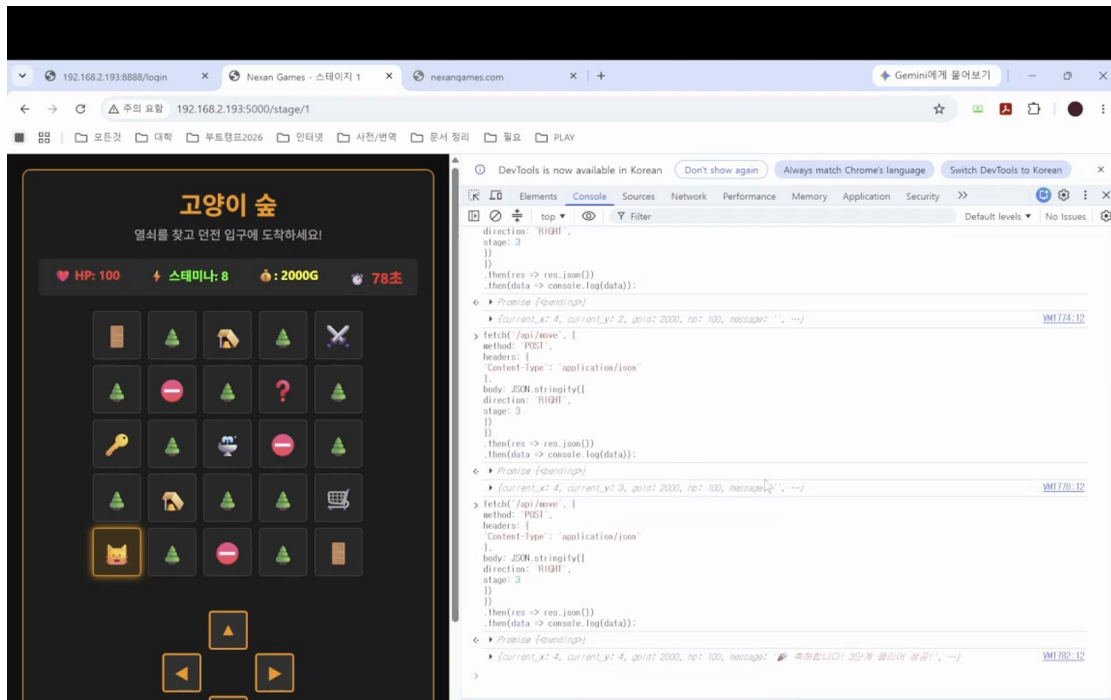
3) 공격 재현 및 결과 증적



[그림 V-01-1] 로비에서 확인한 정상 스테이지 선택 화면



[그림 V-01-2] Burp Suite 에서 스테이지 이동 요청 값을 확인한 화면



[그림 V-01-3] 변조 요청 후 스테이지 화면에 접근한 결과

4) 취약점 원인

원인	설명
서버 측 단계 검증 부족	클라이언트가 전송한 stage 값과 사용자의 실제 클리어 상태를 서버에서 충분히 대조하지 않음
클라이언트 상태 의존	화면에서 보이는 진행 상태와 요청 값만으로 판단하여 /api/move 직접 변조 요청에 취약함

5) 공격 재현 절차

- 일반 사용자 계정으로 로그인한 뒤 로비 또는 스테이지 화면에 접근한다.
- Burp Suite 에서 /api/move 또는 스테이지 이동 요청을 가로챈다.
- 요청 본문의 stage 값을 현재 진행 가능한 단계와 다른 값으로 변경한다.
- 서버 응답과 실제 화면에서 상위 스테이지 접근 가능 여부를 확인한다.

6) 공격 요청 예시

```
POST /api/move HTTP/1.1
Host: 192.168.219.174:5000
Content-Type: application/json

{"direction":"UP","stage":"변조값"}
```

7) 공격 결과 판단 기준

확인 항목	취약 상태 판단 기준
확인	stage 값 변조 요청이 서버에서 처리됨

확인	이전 스테이지 클리어 여부와 무관하게 미해금 스테이지 접근 또는 이동 결과가 반환됨
확인	access.log 또는 GoAccess 에 해당 요청 기록이 남음

8) 영향도

이전 스테이지 클리어 조건이 우회되어 미해금 스테이지에 비정상적으로 진입할 수 있다. 이로 인해 게임 진행 순서와 보상 체계가 왜곡될 수 있으므로, 서버 기준의 클리어 상태 검증과 요청 stage 값 검증이 필요하다.

9) 위험도 평가

평가 항목	평가
발생 가능성	중간
기술 난이도	낮음~중간
영향도	중간
탐지 가능성	중간
최종 위험도	Medium

10) 대응 방안

- 스테이지 접근 시 사용자별 클리어 기록을 서버에서 재조회한다.
- stage 값은 정수 범위와 현재 진행 가능 단계 기준으로 검증한다.
- 비정상 stage 요청은 실패 응답과 함께 로그로 기록한다.

11) 관련 로그 및 관제 증적

로그 위치	확인 내용	사진 삽입 기준
WEB access.log / GoAccess	해당 기능 URL 요청, 응답 코드, 요청 시각 확인	요청 URL, IP, status code 가 보이도록 캡처
Wazuh	비정상 입력, 파일 생성, 명령 실행 직후 확인	이벤트명, 에이전트, 룰 ID, 심각도 표시
DB / 서버 로그	DB 반영값, 예외 로그, 업로드 파일명, 처리 결과 확인	user_id, 파라미터 값, created_at 또는 로그 시각 표시

V-02. 상점 가격 조작

1) 취약점 개요

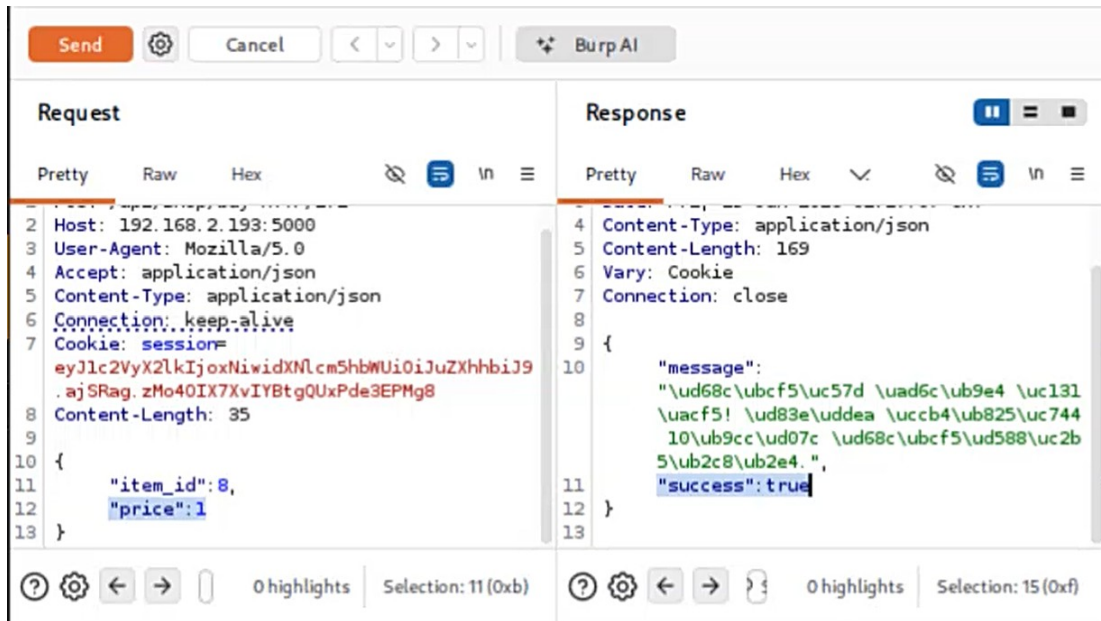
상점 구매 요청에서 클라이언트가 전달한 price 값을 서버가 신뢰하면 공격자가 Burp Suite 에서 가격을 낮추거나 음수로 조작하여 실제 가격과 다른 금액으로 아이템을 구매할 수 있다.

2) 취약점 정보

항목	내용
취약점 ID	V-02
취약점명	상점 가격 조작

위험도	High
영향 대상	상점 기능, 게임 DB
발생 위치	/api/shop/buy
요청 방식	POST
관련 파라미터	item_id, price
증적 출처	공격 시연 영상 모음 및 추가 친구 XSS 시연 영상 캡처

3) 공격 재현 및 결과 증적



[그림 V-02-1] Burp Suite 에서 상점 구매 요청의 price 값을 조작한 화면



[그림 V-02-2] 변조 요청 후 상점 화면에서 구매 결과를 확인한 화면

4) 취약점 원인

원인	설명
----	----

클라이언트 가격값 신뢰	서버가 item_id 기준 실제 가격을 DB 에서 재조회하지 않고 요청 price 값을 사용함
트랜잭션 검증 부족	보유 골드 차감, 아이템 지급, 구매 이력 저장이 서버 기준 가격으로 일관되게 검증되지 않음

5) 공격 재현 절차

- 상점 페이지에서 아이템 구매 요청을 발생시킨다.
- Burp Suite Repeater 로 요청을 보낸 뒤 price 값을 정상 가격과 다른 값으로 변경한다.
- 변조 요청을 전송하고 서버 응답과 게임 화면의 구매 결과를 확인한다.

6) 공격 요청 예시

```
POST /api/shop/buy HTTP/1.1
Host: 192.168.219.174:5000
Content-Type: application/json

{"item_id":8,"price":"변조값"}
```

7) 공격 결과 판단 기준

확인 항목	취약 상태 판단 기준
확인	변조된 price 값으로 구매 성공 응답이 반환됨
확인	아이템이 인벤토리에 추가되거나 상점 화면에서 구매 성공이 확인됨

8) 영향도

공격자는 게임 재화를 정상보다 적게 사용하거나 비정상 가격으로 아이템을 획득할 수 있다. 대량 반복 시 게임 경제와 아이템 희소성이 훼손된다.

9) 위험도 평가

평가 항목	평가
발생 가능성	높음
기술 난이도	낮음~중간
영향도	높음
탐지 가능성	중간
최종 위험도	High

10) 대응 방안

- 서버는 item_id 기준으로 실제 가격을 DB 에서 재조회한다.
- 클라이언트 price 파라미터는 처리 기준에서 제외하거나 참고값으로만 사용한다.
- 구매 처리는 트랜잭션과 행 잠금을 적용하여 골드 음수 및 중복 지급을 방지한다.

11) 관련 로그 및 관제 증적

로그 위치	확인 내용	사진 삽입 기준
-------	-------	----------

WEB access.log / GoAccess	해당 기능 URL 요청, 응답 코드, 요청 시각 확인	요청 URL, IP, status code 가 보이도록 캡처
Wazuh	비정상 입력, 파일 생성, 명령 실행 징후 확인	이벤트명, 에이전트, 룰 ID, 심각도 표시
DB / 서버 로그	DB 반영값, 예외 로그, 업로드 파일명, 처리 결과 확인	user_id, 파라미터 값, created_at 또는 로그 시각 표시

V-03. 쿠폰 중복 수령 가능

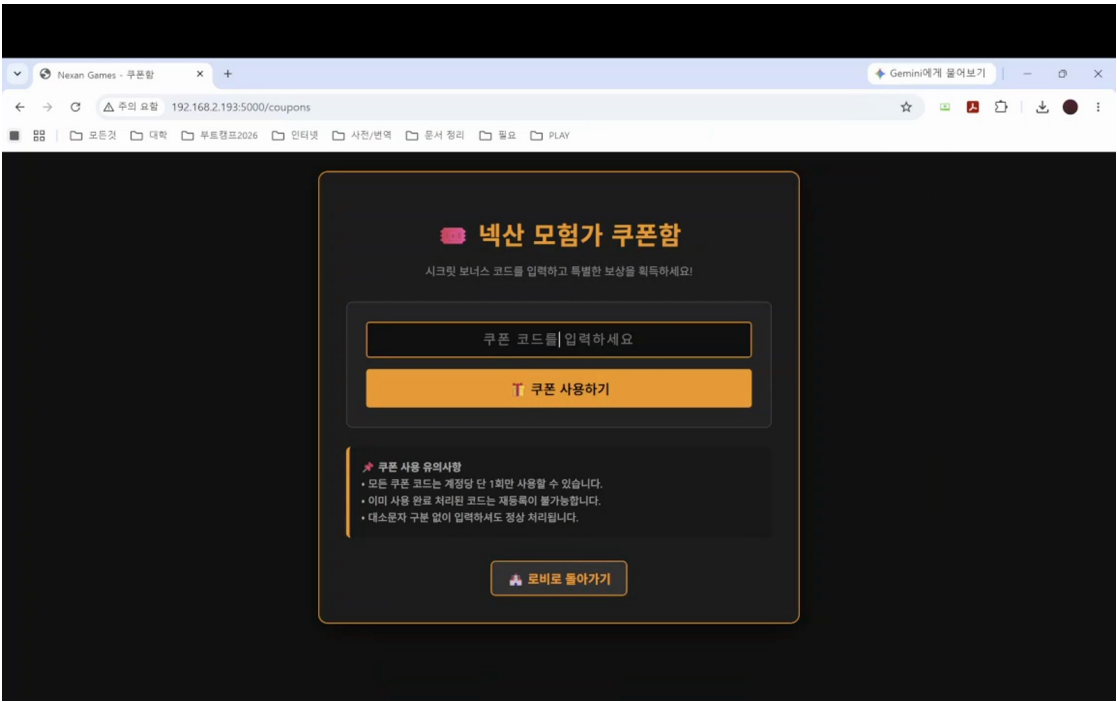
1) 취약점 개요

쿠폰 사용 기능에서 동일 사용자와 동일 쿠폰 코드 조합에 대한 사용 이력 검증이 미흡하면, 같은 쿠폰을 반복 요청하여 보상을 여러 번 수령할 수 있다.

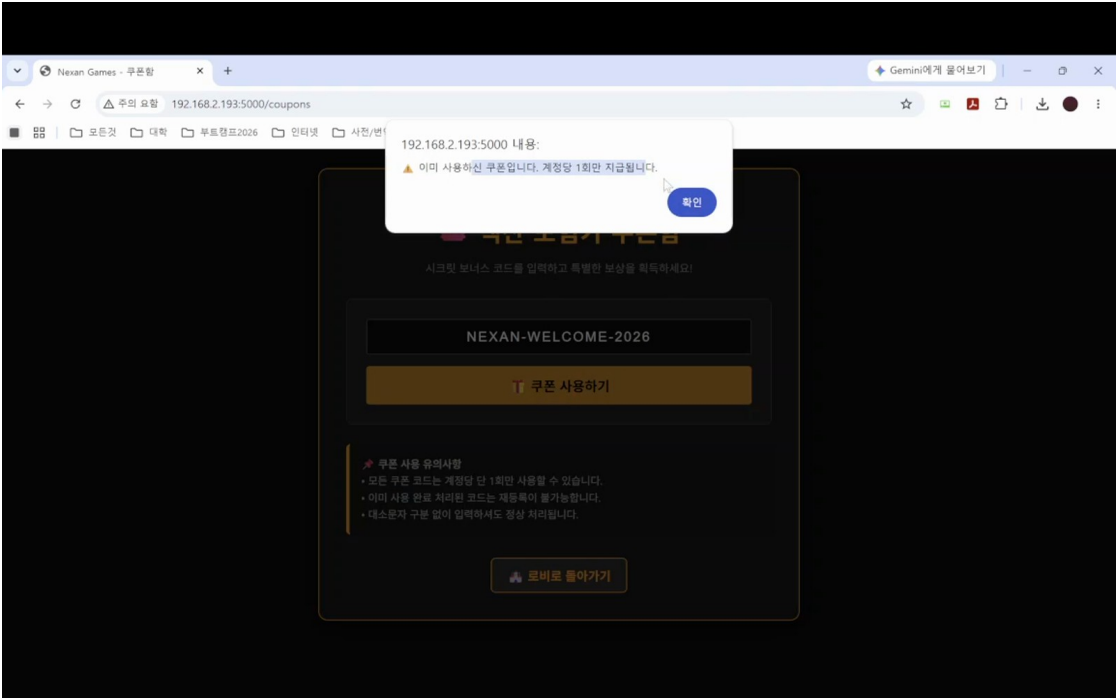
2) 취약점 정보

항목	내용
취약점 ID	V-03
취약점명	쿠폰 중복 수령 가능
위험도	High
영향 대상	쿠폰 보상 로직, 사용자 보상 DB
발생 위치	쿠폰 사용 페이지 및 쿠폰 처리 API
요청 방식	POST
관련 파라미터	coupon_code
증적 출처	공격 시연 영상 모음 및 추가 친구 XSS 시연 영상 캡처

3) 공격 재현 및 결과 증적



[그림 V-03-1] 쿠폰함에서 쿠폰 코드를 입력하는 화면



[그림 V-03-2] 쿠폰 사용 요청 후 보상 수령 성공 알림 화면

4) 취약점 원인

원인	설명
중복 사용 검증 미흡	user_id 와 coupon_code 조합의 기존 사용 여부를 서버에서 확실히 차단하지 않음

DB 제약조건 부족	동일 사용자와 동일 쿠폰에 대한 UNIQUE 제약조건 또는 원자적 트랜잭션 처리가 부족함
------------	---

5) 공격 재현 절차

- 쿠폰함에서 유효한 쿠폰 코드를 입력한다.
- 정상 사용 요청을 Burp Suite 에서 확인하거나 동일 코드를 반복 입력한다.
- 동일 쿠폰 요청을 재전송하고 보상 지급 여부를 확인한다.
- 사용자 골드, 경험치, 아이템 수량 또는 쿠폰 사용 이력 테이블을 확인한다.

6) 공격 요청 예시

POST /coupons HTTP/1.1 Host: 192.168.219.174:5000 Content-Type: application/x-www-form-urlencoded coupon_code=동일쿠폰코드

7) 공격 결과 판단 기준

확인 항목	취약 상태 판단 기준
확인	동일 쿠폰 코드로 두 번 이상 성공 응답이 반환됨
확인	골드 또는 보상 수량이 반복 증가함
확인	쿠폰 사용 이력에서 중복 지급 흔적이 확인됨

8) 영향도

공격자는 쿠폰 보상을 반복 수령하여 게임 재화와 아이템을 부정 획득할 수 있다. 게임 경제와 이벤트 보상 정책이 손상된다.

9) 위험도 평가

평가 항목	평가
발생 가능성	높음
기술 난이도	낮음~중간
영향도	높음
탐지 가능성	중간
최종 위험도	High

10) 대응 방안

- 쿠폰 사용 전 user_id+coupon_code 사용 이력을 서버에서 검증한다.
- DB 에 UNIQUE(user_id, coupon_code) 제약조건을 적용한다.
- 보상 지급과 사용 이력 저장을 하나의 트랜잭션으로 처리한다.

11) 관련 로그 및 관제 증거

로그 위치	확인 내용	사진 삽입 기준
-------	-------	----------

WEB access.log / GoAccess	해당 기능 URL 요청, 응답 코드, 요청 시각 확인	요청 URL, IP, status code 가 보이도록 캡처
Wazuh	비정상 입력, 파일 생성, 명령 실행 징후 확인	이벤트명, 에이전트, 룰 ID, 심각도 표시
DB / 서버 로그	DB 반영값, 예외 로그, 업로드 파일명, 처리 결과 확인	user_id, 파라미터 값, created_at 또는 로그 시각 표시

V-04. Flask Debug Traceback 정보 노출

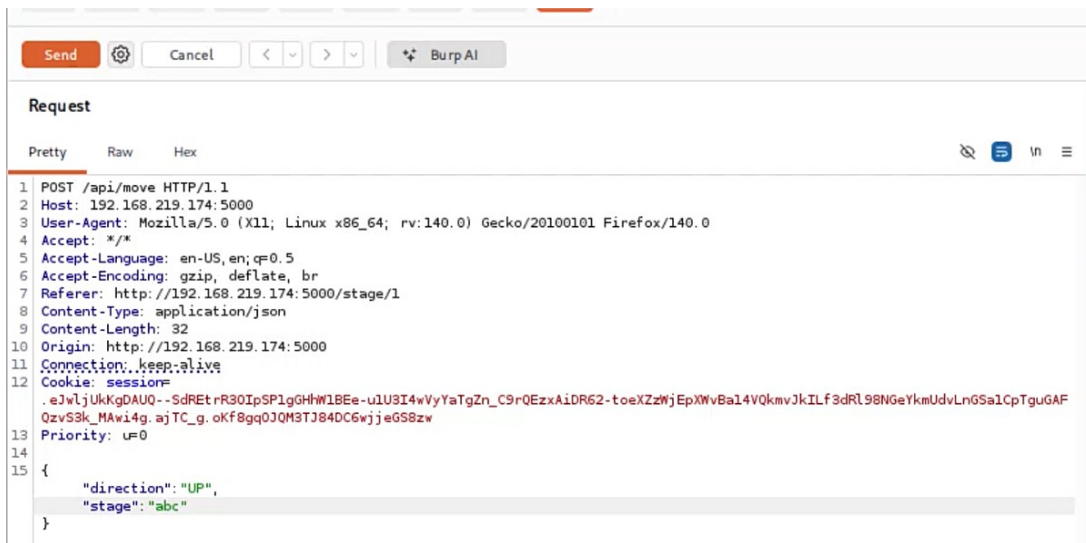
1) 취약점 개요

요청 파라미터에 비정상 문자열을 입력했을 때 서버가 예외를 적절히 처리하지 못하고 Flask Debug Traceback 화면을 반환하였다. 해당 화면에는 서버 내부 경로, 파일명, 함수명, 코드 라인 등이 포함된다.

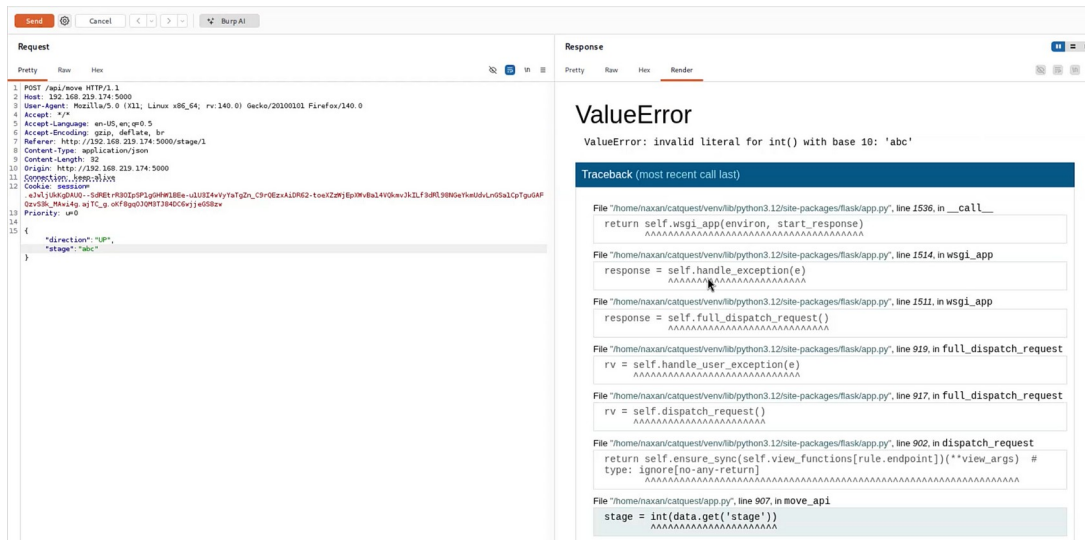
2) 취약점 정보

항목	내용
취약점 ID	V-04
취약점명	Flask Debug Traceback 정보 노출
위험도	High
영향 대상	Flask 웹 애플리케이션, 서버 내부 정보
발생 위치	/api/move 등 입력값 처리 API
요청 방식	POST
관련 파라미터	stage 등 정수 변환 입력값
증적 출처	공격 시연 영상 모음 및 추가 친구 XSS 시연 영상 캡처

3) 공격 재현 및 결과 증적



[그림 V-04-1] Burp Suite 에서 비정상 stage 값을 입력한 요청 화면



[그림 V-04-2] Flask Debug Traceback 응답이 노출된 화면

4) 취약점 원인

원인	설명
운영환경 debug 활성화	개발용 디버그 설정이 운영성 테스트 환경에 남아 있음
입력값 검증 부족	정수 변환이 필요한 값에 문자열을 입력해도 사전 검증 없이 처리함
공통 오류 처리 부재	예외 발생 시 사용자에게 상세 traceback 을 반환함

5) 공격 재현 절차

- /api/move 요청을 Burp Suite 에서 가로챈다.
- stage 파라미터에 숫자가 아닌 문자열을 입력한다.
- 요청을 전송하고 응답 화면에 traceback 이 노출되는지 확인한다.
- 노출된 서버 경로, 함수명, 코드 라인을 증적으로 기록한다.

6) 공격 요청 예시

```
POST /api/move HTTP/1.1
Host: 192.168.219.174:5000
Content-Type: application/json

{"direction":"UP","stage":"abc"}
```

7) 공격 결과 판단 기준

확인 항목	취약 상태 판단 기준
확인	서버가 일반 오류 페이지 대신 Werkzeug/Flask Traceback 을 반환함
확인	/home/.../app.py 와 같은 내부 파일 경로가 보임
확인	함수명과 코드 라인이 응답에 포함됨

8) 영향도

공격자는 내부 디렉터리 구조와 라우팅 함수, 취약한 코드 위치를 파악할 수 있다. 직접적인 권한 탈취는 아니지만 후속 공격 경로 분석에 큰 단서를 제공한다.

9) 위험도 평가

평가 항목	평가
발생 가능성	높음
기술 난이도	낮음~중간
영향도	높음
탐지 가능성	중간
최종 위험도	High

10) 대응 방안

- 운영 환경에서 debug=False 및 FLASK_DEBUG=0 을 적용한다.
- 입력값 타입과 범위를 라우트 초기에 검증한다.
- 사용자에게는 공통 오류 페이지를 제공하고 상세 예외는 서버 로그에만 저장한다.

11) 관련 로그 및 관제 증적

로그 위치	확인 내용	사진 삽입 기준
WEB access.log / GoAccess	해당 기능 URL 요청, 응답 코드, 요청 시각 확인	요청 URL, IP, status code 가 보이도록 캡처
Wazuh	비정상 입력, 파일 생성, 명령 실행 징후 확인	이벤트명, 에이전트, 룰 ID, 심각도 표시
DB / 서버 로그	DB 반영값, 예외 로그, 업로드 파일명, 처리 결과 확인	user_id, 파라미터 값, created_at 또는 로그 시각 표시

V-05. 공지사항 작성 및 수정 페이지 XSS

1) 취약점 개요

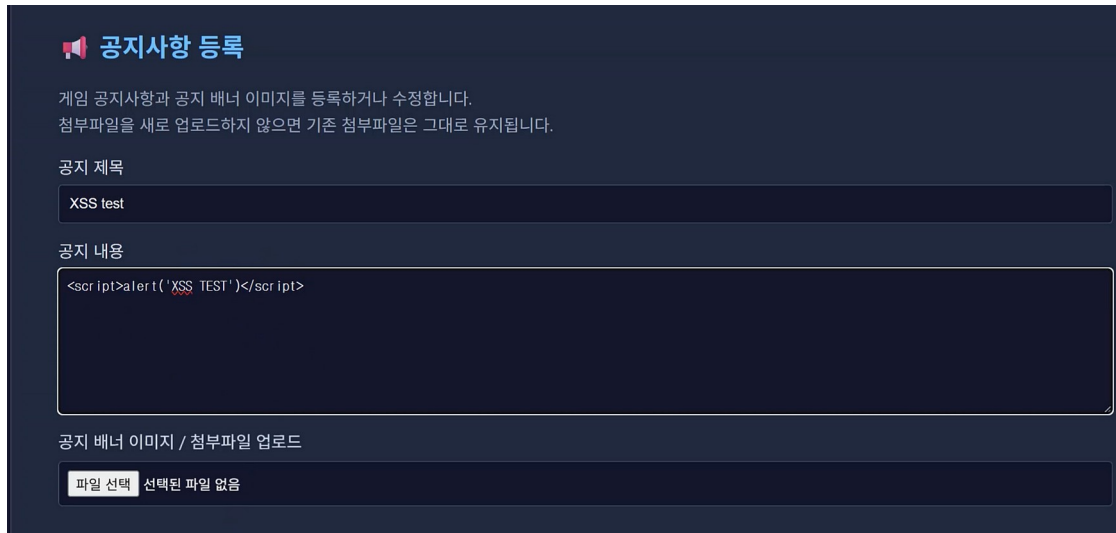
공지사항 작성 및 수정 기능에서 제목 또는 본문 입력값에 대한 HTML/스크립트 필터링이 미흡하여, 공지 등록 또는 수정 작업을 수행하는 작성자/수정자 화면에서 스크립트 실행이 확인되었다. 다만 본 시연 기준으로는 일반 사용자가 공지 상세 화면을 열람할 때 스크립트가 실행되는 형태는 확인되지 않았으므로, 영향 범위는 공지 작성·수정 권한자 화면으로 한정하여 판단한다.

2) 취약점 정보

항목	내용
취약점 ID	V-05
취약점명	공지사항 작성 및 수정 페이지 XSS
위험도	High
영향 대상	관리자 공지 기능, 사용자 브라우저

발생 위치	관리자 공지 등록/수정, 공지 상세 페이지
요청 방식	POST
관련 파라미터	title, content
증적 출처	공격 시연 영상 모음 및 추가 친구 XSS 시연 영상 캡처

3) 공격 재현 및 결과 증적



공지사항 등록

게임 공지사항과 공지 배너 이미지를 등록하거나 수정합니다.
첨부파일을 새로 업로드하지 않으면 기존 첨부파일은 그대로 유지됩니다.

공지 제목

XSS test

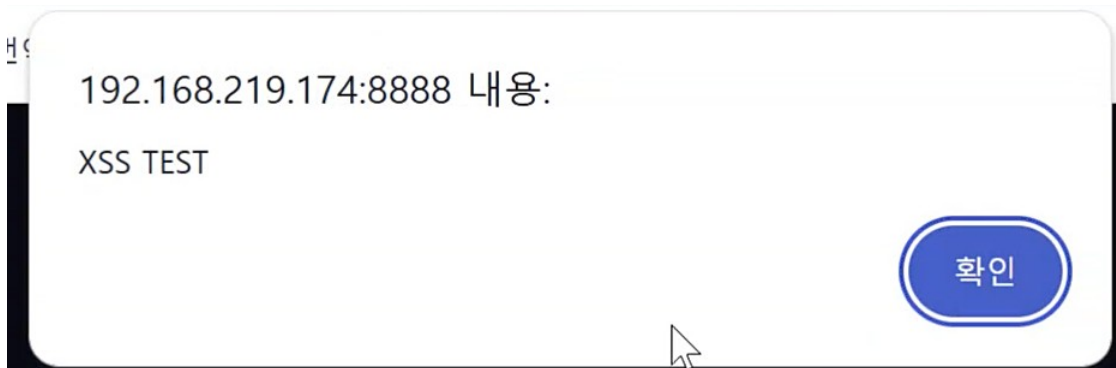
공지 내용

<script>alert('XSS TEST')</script>

공지 배너 이미지 / 첨부파일 업로드

파일 선택 선택된 파일 없음

[그림 V-05-1] 공지사항 작성 화면에 스크립트 입력값을 삽입한 화면

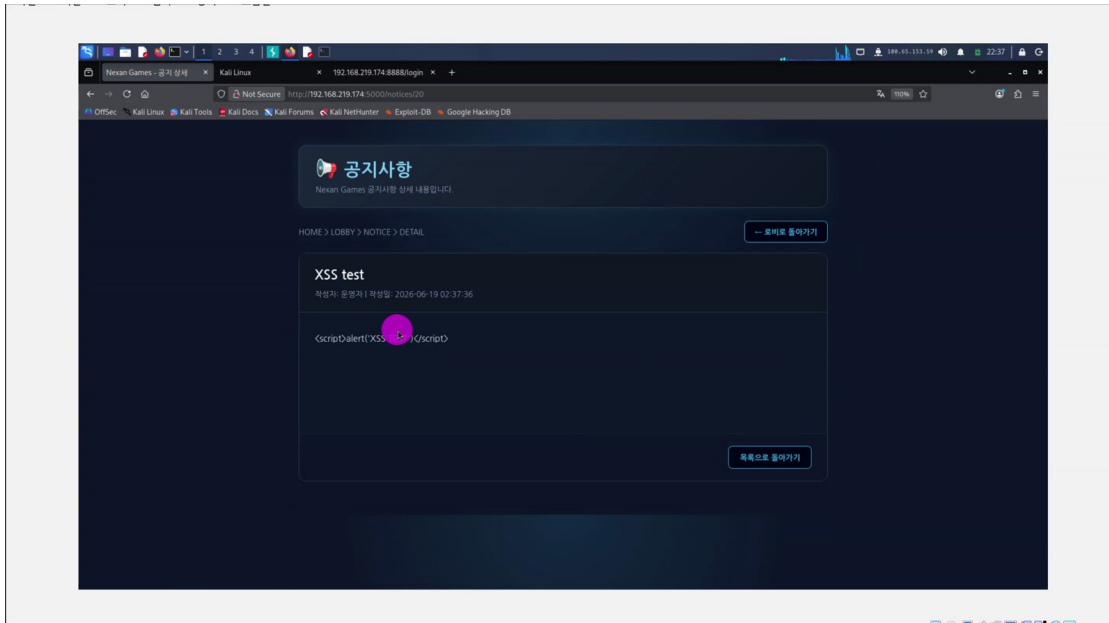


192.168.219.174:8888 내용:

XSS TEST

확인

[그림 V-05-2] 공지사항 작성/수정 화면에서 스크립트 실행이 확인된 화면



[그림 V-05-3] 공지 상세 열람 화면에서는 스크립트 실행이 확인되지 않은 화면

4) 취약점 원인

원인	설명
출력 인코딩 미흡	공지 제목 또는 본문을 HTML 문맥에 출력할 때 안전하게 이스케이프하지 않음
입력값 검증 부족	스크립트 태그, 이벤트 핸들러, 위험한 URL 스킴을 제한하지 않음
관리자 입력 신뢰	관리자 페이지 입력값이라는 이유로 별도 검증을 생략함

5) 공격 재현 절차

- 관리자 공지 등록 또는 수정 페이지에 접근한다.
- 제목 또는 본문에 스크립트 실행 여부를 확인할 수 있는 테스트 입력값을 저장한다.
- 공지 등록 또는 수정 처리 후 작성자/수정자 화면에서 스크립트 실행 여부를 확인한다.
- 일반 공지 상세 열람 화면에서는 스크립트가 실행되지 않는지 함께 확인하고, 실행 범위와 화면 증거를 구분하여 기록한다.

6) 공격 요청 예시

```
POST /admin/notices/create HTTP/1.1
Host: 192.168.219.174:8888
Content-Type: application/x-www-form-urlencoded

title=테스트&content=스크립트_입력값
```

7) 공격 결과 판단 기준

확인 항목	취약 상태 판단 기준
확인	공지 저장 후 목록 또는 상세 페이지에서 입력값이 HTML 로 해석됨
확인	브라우저 alert 등 스크립트 실행 결과가 확인됨

확인	notices 테이블에 위험 입력값이 저장됨
----	--------------------------

8) 영향도

본 시연에서는 일반 열람자에게 전파되는 저장형 XSS 가 아니라 공지 작성자 또는 수정자 화면에서 스크립트가 실행되는 형태로 확인되었다. 따라서 영향 범위는 제한적이나, 관리자 권한자가 해당 화면을 사용하므로 관리자 세션 노출, 화면 조작, 악성 스크립트 실행으로 이어질 수 있다.

9) 위험도 평가

평가 항목	평가
발생 가능성	높음
기술 난이도	낮음~중간
영향도	높음
탐지 가능성	중간
최종 위험도	High

10) 대응 방안

- 템플릿 출력 시 자동 이스케이프를 적용하고 |safe 사용을 제한한다.
- 허용 태그 기반 Sanitizer 를 적용하거나 HTML 입력을 원천 차단한다.
- 공지 등록/수정 시 위험 패턴을 탐지하고 보안 로그를 남긴다.

11) 관련 로그 및 관제 증거

로그 위치	확인 내용	사진 삽입 기준
WEB access.log / GoAccess	해당 기능 URL 요청, 응답 코드, 요청 시각 확인	요청 URL, IP, status code 가 보이도록 캡처
Wazuh	비정상 입력, 파일 생성, 명령 실행 직후 확인	이벤트명, 에이전트, 룰 ID, 심각도 표시
DB / 서버 로그	DB 반영값, 예외 로그, 업로드 파일명, 처리 결과 확인	user_id, 파라미터 값, created_at 또는 로그 시각 표시

V-06. 친구 메시지 링크 미리보기 XSS 및 명령 실행 가능성

1) 취약점 개요

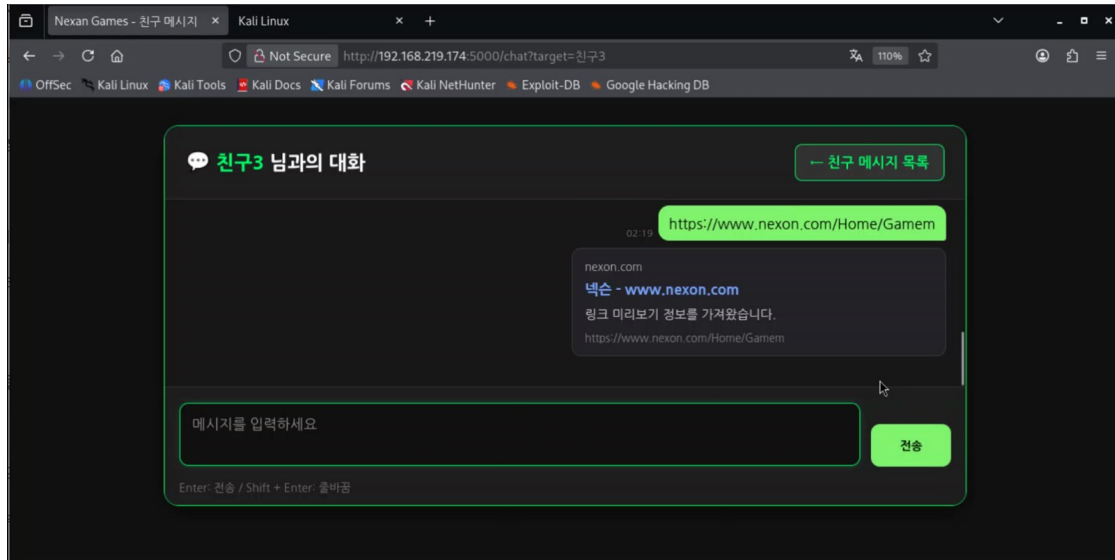
친구 메시지 기능에서 URL 을 포함한 메시지를 수신하면 서버가 링크 미리보기를 생성한다. 이 과정에서 URL 문자열을 안전하게 파싱하지 않고 서버 명령 처리에 연결하면, 메시지 내용만으로 서버 측 요청 처리와 명령 실행 가능성이 발생한다.

2) 취약점 정보

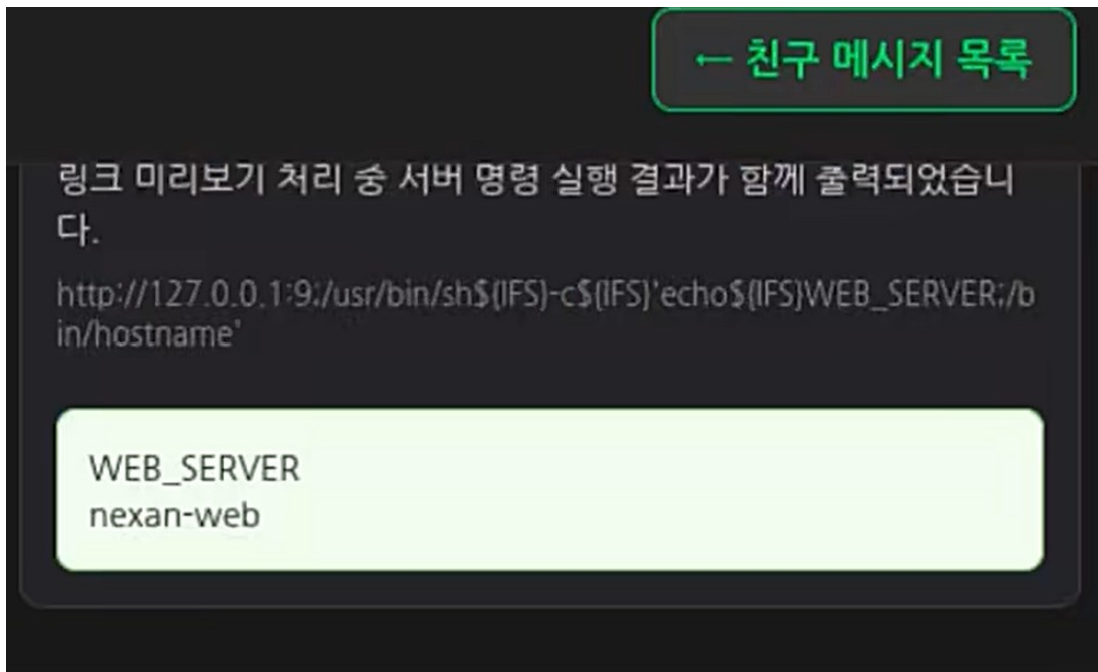
항목	내용
취약점 ID	V-06
취약점명	친구 메시지 링크 미리보기 XSS 및 명령 실행 가능성
위험도	Critical

영향 대상	친구 메시지 기능, 링크 미리보기 처리 서버
발생 위치	친구 메시지 대화방, 링크 미리보기 생성 로직
요청 방식	POST / 서버 측 URL 처리
관련 파라미터	message content, preview URL
증적 출처	공격 시연 영상 모음 및 추가 친구 XSS 시연 영상 캡처

3) 공격 재현 및 결과 증적



[그림 V-06-1] 친구 메시지에 URL 이 포함되어 미리보기 카드가 생성된 화면



[그림 V-06-2] 미리보기 처리 결과로 서버 식별 문자열이 표시된 화면

4) 취약점 원인

원인	설명
URL 파싱 검증 미흡	메시지 내 URL 을 허용 스킴과 호스트 기준으로 안전하게 검증하지 않음
명령어 호출 방식 부적절	미리보기 생성 과정에서 사용자 입력이 OS 명령 문자열에 연결될 가능성이 있음
출력 인코딩 부족	미리보기 제목·설명 출력 시 HTML 문맥에 맞는 이스케이프가 부족함

5) 공격 재현 절차

- 공격자 계정에서 친구 대화방에 URL 이 포함된 메시지를 전송한다.
- 수신자 또는 서버가 메시지를 처리하면서 링크 미리보기 생성이 수행되는지 확인한다.
- 미리보기 처리 결과에 서버 식별 정보 또는 명령 실행 결과가 반영되는지 확인한다.
- 서버 로그와 미리보기 결과 화면을 중심으로 증거를 남기며, 단순 대화 내역 화면은 중복 증거이므로 별도 필수 증거로 사용하지 않는다.

6) 공격 요청 예시

```
POST /chat/send HTTP/1.1
Host: 192.168.219.174:5000
Content-Type: application/json

{"receiver_id":20,"content":"검증용 URL 문자열"}
```

7) 공격 결과 판단 기준

확인 항목	취약 상태 판단 기준
확인	링크를 직접 클릭하지 않아도 서버가 미리보기 생성을 시도함
확인	미리보기 결과에 서버 측 처리 결과가 반영됨
확인	친구 메시지 화면 또는 서버 로그에서 처리 흔적이 확인됨

8) 영향도

메시지 수신자 행위 없이 서버 측 URL 처리 로직이 동작하면 SSRF, 내부 서비스 접근, OS 명령 실행 등으로 확대될 수 있다. 웹서버 권한 획득 시 내부망 이동의 출발점이 될 수 있어 위험도가 높다.

9) 위험도 평가

평가 항목	평가
발생 가능성	높음
기술 난이도	낮음~중간
영향도	매우 높음
탐지 가능성	중간
최종 위험도	Critical

10) 대응 방안

- 미리보기 대상 URL 은 http/https 만 허용하고 내부 IP, localhost, 사설망 대역을 차단한다.
- subprocess 사용 시 shell=True 를 금지하고 인자 배열 방식으로 호출한다.
- 미리보기 결과 출력 시 제목·설명·URL 을 모두 이스케이프한다.
- 미리보기 생성 서버는 네트워크 egress 제한과 타임아웃을 적용한다.

11) 관련 로그 및 관제 증거

로그 위치	확인 내용	사진 삽입 기준
WEB access.log / GoAccess	해당 기능 URL 요청, 응답 코드, 요청 시각 확인	요청 URL, IP, status code 가 보이도록 캡처
Wazuh	비정상 입력, 파일 생성, 명령 실행 징후 확인	이벤트명, 에이전트, 룰 ID, 심각도 표시
DB / 서버 로그	DB 반영값, 예외 로그, 업로드 파일명, 처리 결과 확인	user_id, 파라미터 값, created_at 또는 로그 시각 표시

V-07. 파일명 기반 OS Command Injection

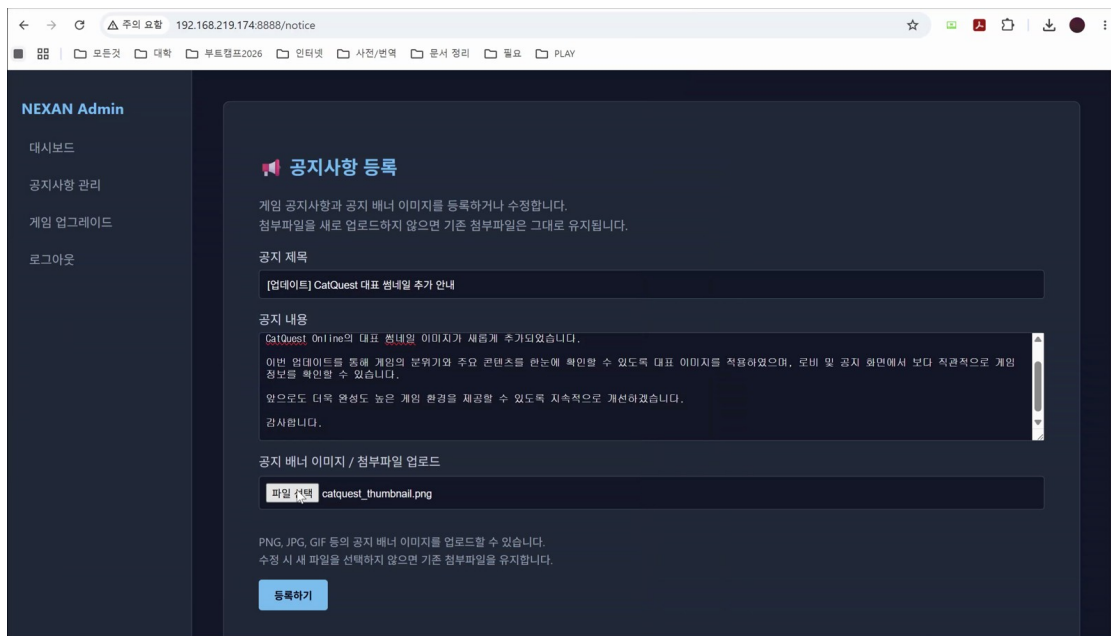
1) 취약점 개요

공지 첨부파일 업로드 기능에서 사용자가 지정한 파일명을 서버의 파일 처리 명령에 그대로 전달하면 파일명에 포함된 명령 구분자가 OS 명령으로 해석될 수 있다. 시연에서는 파일명 조작 후 서버 측 명령 실행 결과가 확인되었다.

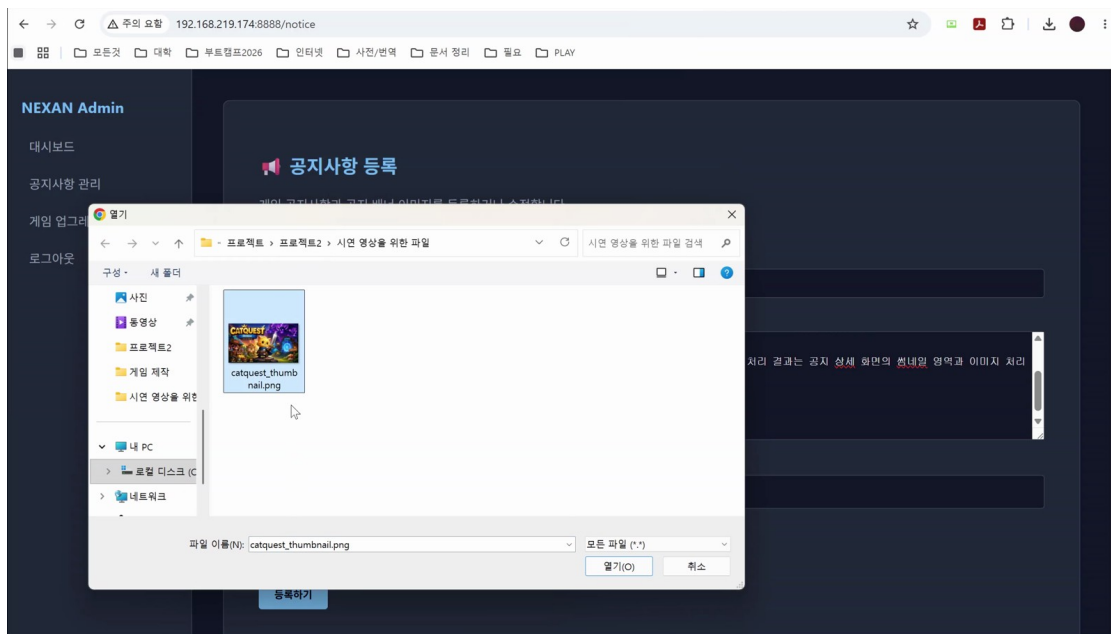
2) 취약점 정보

항목	내용
취약점 ID	V-07
취약점명	파일명 기반 OS Command Injection
위험도	Critical
영향 대상	공지 첨부파일 업로드, 웹서버 파일 시스템
발생 위치	관리자 공지 등록/수정 파일 첨부 기능
요청 방식	POST multipart/form-data
관련 파라미터	attachment filename
증적 출처	공격 시연 영상 모음 및 추가 친구 XSS 시연 영상 캡처

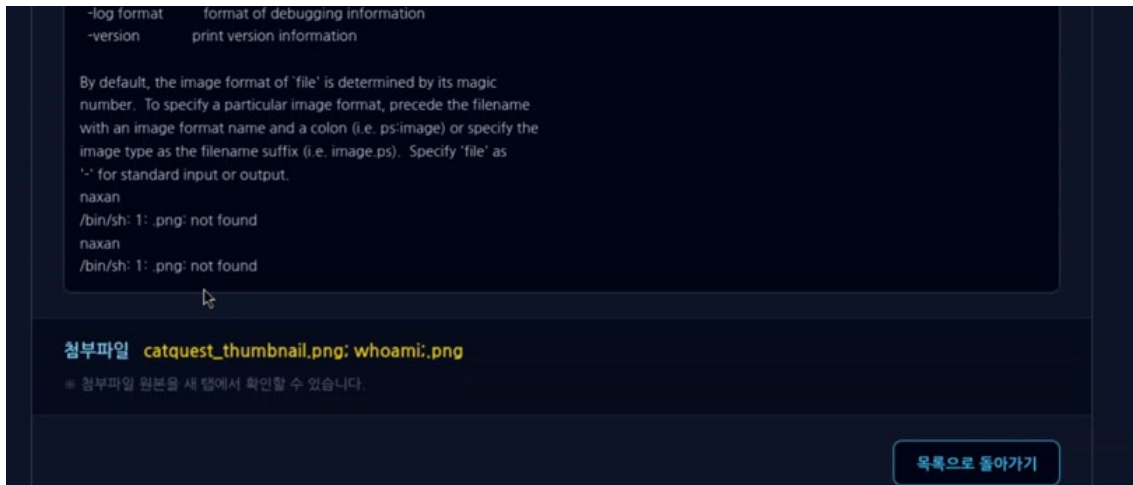
3) 공격 재현 및 결과 증적



[그림 V-07-1] 공지사항 첨부파일 업로드 입력값을 확인한 화면



[그림 V-07-2] 조작된 파일명을 가진 첨부파일을 선택한 화면



[그림 V-07-3] 업로드 처리 후 서버 측 실행 결과가 확인된 화면

4) 취약점 원인

원인	설명
파일명 검증 부족	사용자 입력 파일명에서 명령 구분자와 특수문자를 제거하지 않음
OS 명령 문자열 결합	파일 검증 또는 이미지 처리 과정에서 파일명을 쉘 명령 문자열에 직접 연결함
업로드 처리 로그 부족	업로드 파일명과 처리 결과에 대한 이상 징후 탐지가 부족함

5) 공격 재현 절차

- 관리자 공지 등록 또는 수정 화면에서 첨부파일 업로드 요청을 준비한다.
- 파일명에 명령 구분자가 포함된 테스트 파일명을 사용한다.
- 업로드 요청을 전송하고 서버 응답 또는 처리 결과를 확인한다.
- 웹서버 로그, 업로드 경로, 명령 실행 결과 화면을 증거로 기록한다.

6) 공격 요청 예시

```
POST /admin/notices/create HTTP/1.1
Host: 192.168.219.174:8888
Content-Type: multipart/form-data

filename="cat.png;whoami;.png"
```

7) 공격 결과 판단 기준

확인 항목	취약 상태 판단 기준
확인	특수문자가 포함된 파일명이 서버에서 거부되지 않음
확인	업로드 처리 과정에서 서버 측 명령 실행 결과가 확인됨
확인	서비스 로그 또는 화면에서 웹서버 실행 계정 정보가 확인됨

8) 영향도

공격자는 웹서버 실행 권한으로 명령을 실행할 수 있으며, 이후 내부 파일 조회, 설정 파일 확인, 내부망 접근 시도 등으로 침해 범위가 확대될 수 있다. 운영 환경에서는 Critical 수준으로 즉시 조치가 필요하다.

9) 위험도 평가

평가 항목	평가
발생 가능성	높음
기술 난이도	낮음~중간
영향도	매우 높음
탐지 가능성	중간
최종 위험도	Critical

10) 대응 방안

- 업로드 파일명은 서버에서 UUID 등 안전한 이름으로 재생성한다.
- 허용 확장자와 MIME, magic byte 를 함께 검증한다.
- 파일 처리 시 shell=True 와 문자열 결합을 금지하고 안전한 라이브러리 API 를 사용한다.
- 업로드 디렉터리는 실행 권한을 제거하고 웹 접근을 제한한다.

11) 관련 로그 및 관제 증거

로그 위치	확인 내용	사진 삽입 기준
WEB access.log / GoAccess	해당 기능 URL 요청, 응답 코드, 요청 시각 확인	요청 URL, IP, status code 가 보이도록 캡처
Wazuh	비정상 입력, 파일 생성, 명령 실행 징후 확인	이벤트명, 에이전트, 룰 ID, 심각도 표시
DB / 서버 로그	DB 반영값, 예외 로그, 업로드 파일명, 처리 결과 확인	user_id, 파라미터 값, created_at 또는 로그 시각 표시

보완 예시 및 이행점검 대표 사례

본 항목은 앞서 식별된 여러 취약점 중 보완이 완료된 V-02 상점 가격 조작 사례를 대표 예시로 선정하여, 취약점 조치 후 이행점검을 어떤 방식으로 수행했는지 제시한다. 아래 내용은 V-02 취약점 재현 당시의 증거가 아니라, 전체 취약점 개선 절차를 설명하기 위한 보완 후 재검증 사례이다.

1) 대표 보완 사례 선정 사유

상점 가격 조작 취약점은 클라이언트 입력값 신뢰, 서버 측 검증 부족, DB 기록 부재가 함께 드러난 사례였기 때문에, 보완 전후 차이를 설명하기에 적합하다. 따라서 본 보고서에서는 V-02 를 보완 예시로 사용하여 서버 측 검증 강화와 구매 이력 기록 개선 효과를 확인한다.

2) 보완 방향

- 서버는 item_id 를 기준으로 shop_items 테이블의 실제 가격을 재조회하도록 수정한다.
- 클라이언트가 전달하는 price 값은 결제 기준으로 사용하지 않고, 조작 여부 확인 또는 로그 기록 용도로만 활용한다.
- 구매 처리는 트랜잭션과 행 잠금을 적용하여 골드 음수 차감과 중복 지급을 방지한다.

- 보완 후에는 purchase_history에 실제 구매 금액, 구매 시각, 사용자 정보가 기록되도록 하여 사후 추적성을 확보한다.

3) 이행점검 기준

- 임의로 낮춘 price 값을 전송해도 서버가 DB 기준 정상 가격으로 처리하거나 요청을 차단하는지 확인한다.
- 정상 가격 기준으로 사용자 골드가 차감되는지 확인한다.
- 구매 성공 시 purchase_history에 실제 구매 금액과 created_at 값이 기록되는지 확인한다.
- 비정상 구매 요청이 웹 로그 또는 서버 로그에 남아 사후 분석이 가능한지 확인한다.

구분	취약 상태	보완 후
가격 기준	클라이언트 요청의 price 값에 의존	서버가 shop_items의 실제 가격을 재조회
결제 처리	변조된 가격으로 구매 처리 가능	트랜잭션 및 행 잠금으로 정상 가격 차감
기록/추적	구매 히스토리 기반 추적이 부족	purchase_history에 보완 후 구매 금액과 시각 기록
검증 결과	임의 가격 요청 시 구매 결과 변조 가능	임의 가격 요청 차단 및 정상 가격 기준 처리 확인

※ 본 표는 취약점 항목 내부의 재현 증적이 아니라, 보완 이후 대표 이행점검 결과를 정리한 예시이다.

9. 취약점별 탐지 및 로그 증적 요약

다음 표는 취약점별로 GoAccess, Wazuh, DB/서버 로그에서 확인한 탐지 항목과 주요 증적을 정리한 것이다.

취약점 ID	취약점명	GoAccess 확인 항목	Wazuh 확인 항목	DB/서버 로그 확인 항목
V-01	스테이지 API 요청 조작	/api/move 요청 및 응답 코드	비정상 stage 값 요청 탐지	요청 stage 값, 클리어 상태, 세션 user_id 비교
V-02	상점 가격 조작	/api/shop/buy 요청 빈도 및 응답 코드	비정상 API 요청 탐지	상점 API 처리 로그, users 골드 변화
V-03	쿠폰 중복 수령 가능	쿠폰 요청 반복 및 성공 응답	동일 API 반복 요청 탐지	쿠폰 사용 이력, 보상 증가 기록
V-04	Flask Debug Traceback 정보 노출	500 응답 증가, 오류 유발 URL	웹 오류 및 traceback 이벤트	systemd journal, Flask 예외 로그
V-05	공지사항 작성 및 수정 페이지 XSS	공지 작성/수정 요청 및 상세 페이지 접근	스크립트 포함 입력 탐지	notices 테이블 title/content 값 확인
V-06	친구 메시지 링크 미리보기 XSS 및 명령 실행 가능성	/chat, 링크 미리보기 요청 패턴	비정상 URL 처리 및 명령 실행 징후	messages 테이블, 미리보기 처리 로그
V-07	파일명 기반 OS Command Injection	공지 첨부파일 업로드 POST 요청	업로드 경로 파일 생성 및 프로세스 실행 징후	업로드 파일명, 저장 경로, 서비스 로그

GoAccess Dashboard Evidence

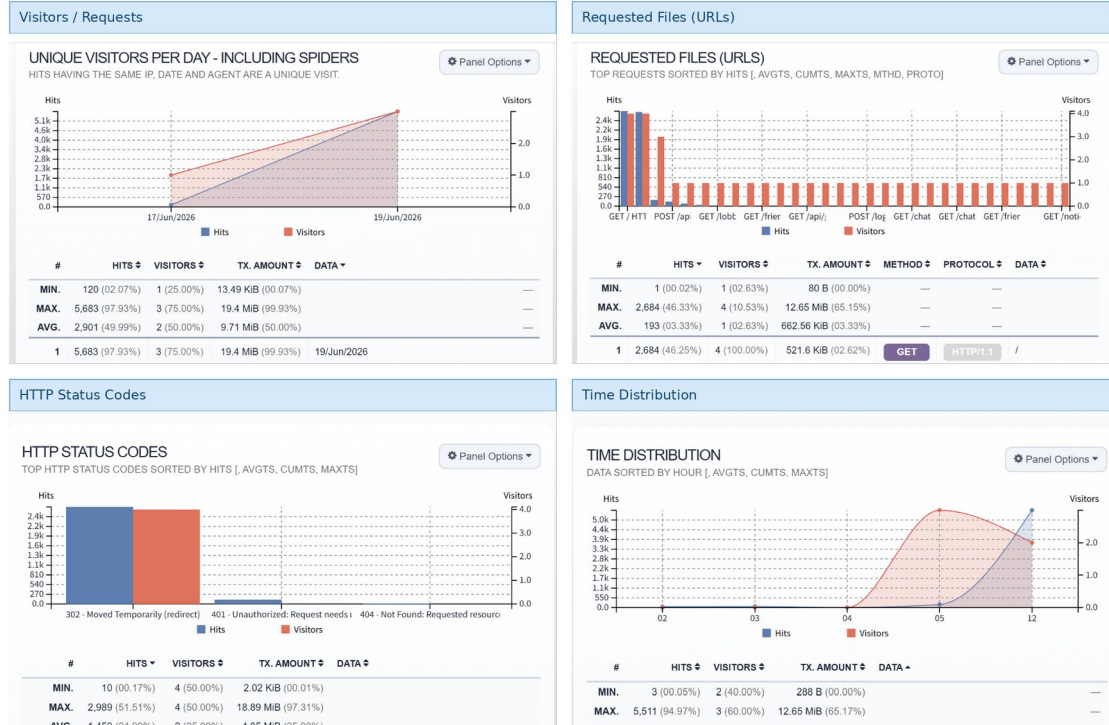


그림 9-1 GoAccess 대시보드 전체 화면

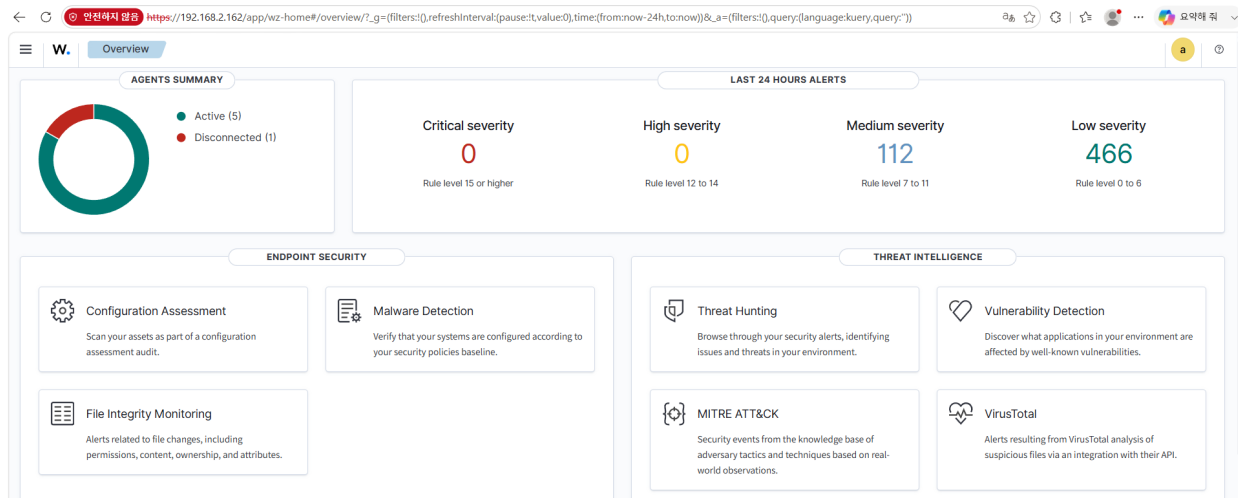


그림 9-4 Wazuh 대시보드에서 에이전트 및 최근 24 시간 알림 현황을 확인한 화면

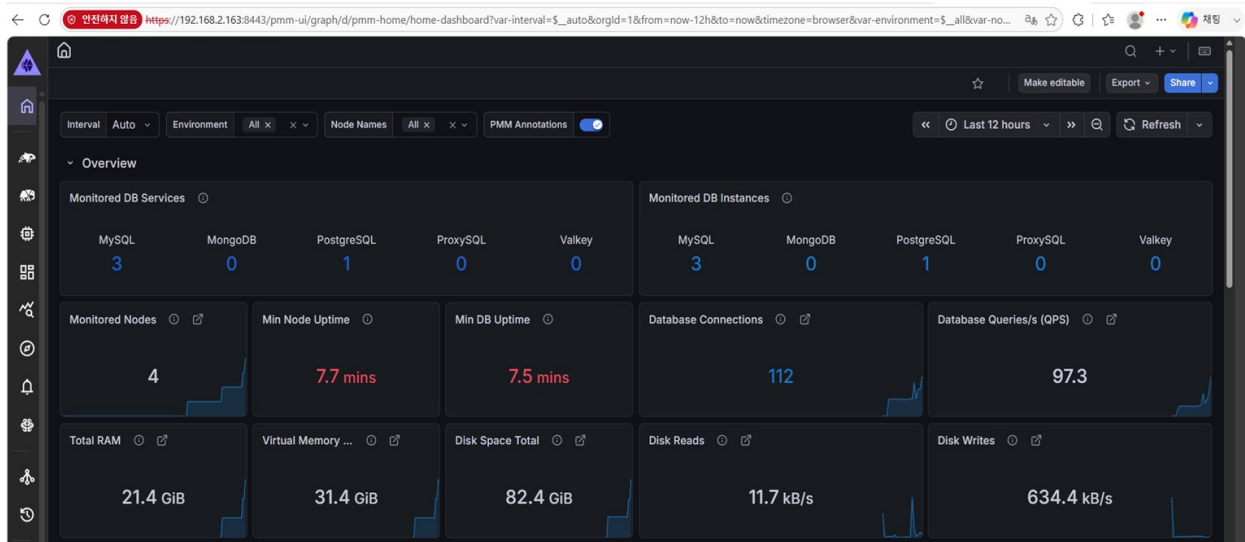


그림 9-5 PMM 대시보드에서 DB 서비스 및 연결 수, QPS 를 확인한 화면



그림 9-2 /api/shop/buy 요청 증가 화면

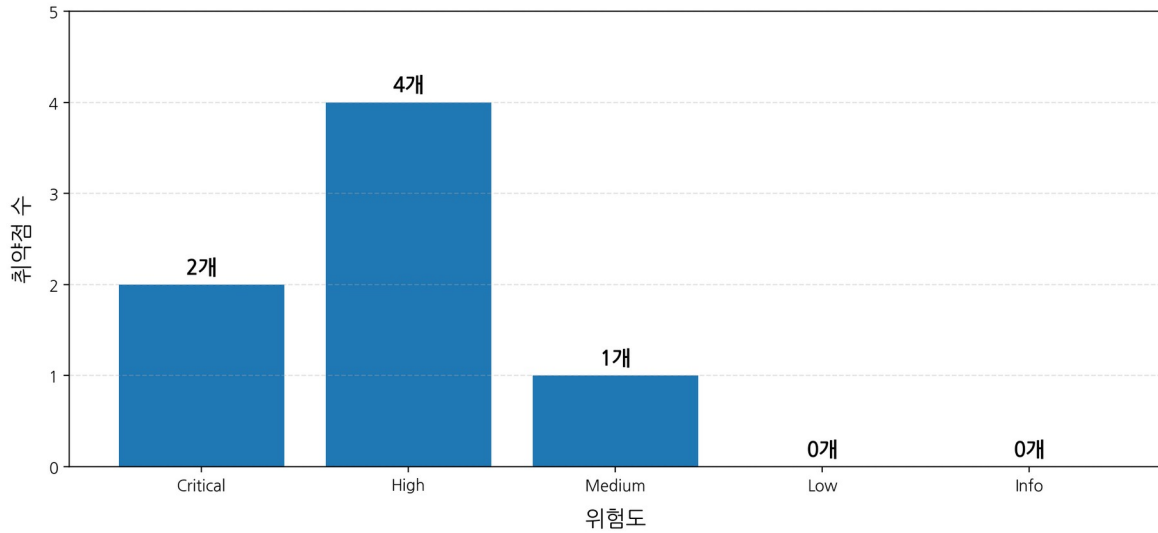


그림 9-3 /coupons 반복 요청 화면

10. 종합 위험도 평가

위험도	취약점 수	주요 항목
Critical	2 개	친구 메시지 링크 미리보기 XSS 및 명령 실행 가능성, 파일명 기반 OS Command Injection
High	4 개	상점 가격 조작, 쿠폰 중복 수령 가능, Flask Debug Traceback 정보 노출, 공지사항 XSS
Medium	1 개	스태이지 API 요청 조작
Low	0 개	해당 없음
Info	0 개	개선 권고 항목

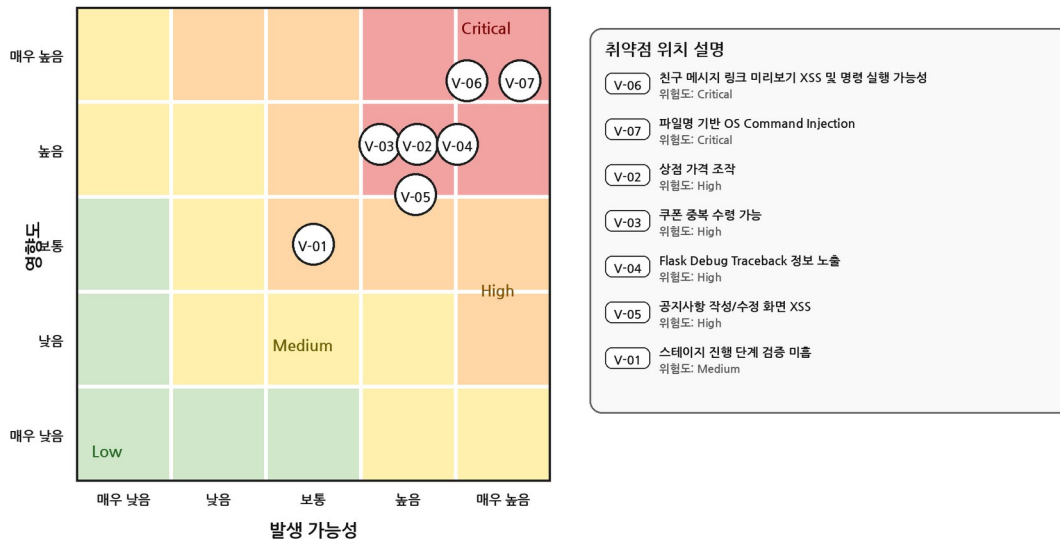
취약점 위험도 분포



총 7개 취약점: Critical 2개, High 4개, Medium 1개

그림 10-1 위험도 분포 그래프

취약점별 위험도 매트릭스



※ 동그라미 안에는 V-번호만 표시하고, 상세 취약점명은 오른쪽 범례에 분리하여 가독성을 높임

그림 10-2 취약점별 위험도 매트릭스

11. 보안 권고안

11.1 웹 애플리케이션 보안

- 클라이언트에서 전달되는 가격, 공격력, 체력, 보상값을 신뢰하지 않는다.
- 모든 중요 계산은 서버에서 수행한다.
- 사용자 입력값은 저장 전 검증하고 출력 시 이스케이프 처리한다.
- 객체 접근 시 현재 로그인 사용자와 소유자를 비교한다.
- 관리자 기능은 역할 기반 접근 제어를 적용한다.

11.2 서버 보안

- 웹 루트에 백업 파일을 저장하지 않는다.
- 업로드 디렉터리에는 실행 권한을 부여하지 않는다.
- 민감 설정 파일은 외부 접근이 불가능한 경로에 저장한다.
- 서비스 계정은 최소 권한으로 실행한다.
- 불필요한 포트와 서비스를 차단한다.

11.3 DB 보안

- DB 접속 정보는 코드에 하드코딩하지 않는다.
- 게임 DB와 개인정보 DB 계정을 분리한다.
- 개인정보 DB는 필요한 서버에서만 접근 가능하도록 제한한다.
- DB 계정에는 최소 권한만 부여한다.
- 개인정보는 암호화 또는 마스킹을 적용한다.
- DB 접속 실패 및 이상 쿼리를 로그로 기록한다.

11.4 네트워크 보안

- DMZ에서 내부 서버망으로의 접근은 필요한 포트만 허용한다.
- WEB 서버에서 개인정보 DB로 직접 접근 가능한지 재검토한다.
- VLAN 간 접근 제어 정책을 명확히 설정한다.
- 보안팀 VLAN에서만 관리 포트 접근을 허용한다.
- 외부망에서 내부 서버망으로 직접 접근하지 못하도록 차단한다.

11.5 로그 및 보안관제

- WEB access.log를 중앙 로그 서버로 전송한다.
- 관리자 페이지 접근 시도를 별도 로그로 기록한다.
- 가격 조작, 쿠폰 중복, IDOR 의심 요청을 탐지 룰로 등록한다.
- 파일 업로드 이벤트를 Wazuh에서 탐지한다.
- DB 접속 실패 이벤트를 PMM 또는 DB-Log에서 확인한다.
- GoAccess로 비정상 URL 요청 패턴을 분석한다.
- Zabbix로 CPU, 메모리, 디스크, 서비스 상태 변화를 모니터링한다.

12. 최종 결론

CatQuest Online은 게임 웹 서비스, 관리자 페이지, 게임 DB, 개인정보 DB, 로그 및 보안관제 시스템을 포함하고 있어 실제 게임회사 환경과 유사한 보안 진단 시나리오를 구성할 수 있었다. 진단 결과, 클라이언트 요청값 신뢰, 서버 측 접근제어 미흡, 객체 소유권 검증 누락, 파일 업로드 검증 미흡, 운영 환경 Debug 모드 노출 등이 주요 보안 위험으로 도출되었다.

특히 게임 서비스 특성상 상점 가격 조작, 쿠폰 중복 수령, 쿠폰 중복 수령은 게임 경제와 보상 체계에 직접적인 영향을 줄 수 있다. 또한 Flask Debug Traceback 정보 노출, 공지사항 XSS, 친구 메시지 링크 미리보기 XSS 및 명령 실행 가능성, 파일명 기반 OS Command Injection은 정보 노출 및 추가 침해로 이어질 수 있으므로 우선 조치가 필요하다.

보안관제 측면에서는 공격 요청이 웹 로그, Wazuh, GoAccess, Zabbix, PMM 등에 기록되는지 확인하고, 탐지되지 않는 항목에 대해서는 별도 탐지 룰과 파일 무결성 감시 대상을 추가해야 한다. 향후에는 취약점 조치 후 이행점검을 수행하고, DMZ와 내부 서버망 간 접근 제어를 강화하며, 개인정보 DB에 대한 접근 권한과 로그 기록을 더욱 엄격히 관리해야 한다.